RÉPUBLIQUE DU SÉNÉGAL

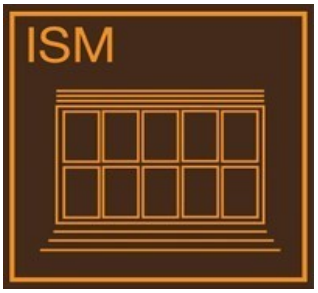


Un peuple-Un but-Une foi

Ministère de l'enseignement Supérieur de la Recherche et de l'innovation

Direction Générale de l'Enseignement Supérieur Privé

Institut Supérieur de Management



Présenter par :

Nom & Prénom : SARR Pape Aldiouma

Classe : L3 Cybersécurité

Module : Cyber Sécurité & Ethical Hacking

Date : 27 Septembre 2026

Sujet : pare-feu OPNsense, segmentation LAN / WAN / DMZ,
VPN IPsec nomade et publication d'une application Docker en DMZ

Sous la supervision de : Mr Ousmane Ndiaye

SOMMAIRE

1. Introduction et Objectifs
2. Concepts clés à comprendre avant de commencer
    - 2-1 Virtualisation, hyperviseur, machine virtuelle
    - 2-2 QEMU, KVM, libvirt, virt-manager
    - 2-3 Réseaux virtuels : bridge, NAT, réseau isolé
    - 2-4 Pare-feu et zones réseau : WAN, LAN, DMZ
    - 2-5 VPN et IPsec
    - 2-6 Docker, conteneurs et reverse proxy
3. Architecture cible
    - 3-1 Schéma logique
    - 3-2 Plan d'adressage IP
    - 3-3 Ressources recommandées pour chaque VM
4. Création des réseaux virtuels
    - 4-1 Réseau WAN (NAT)
    - 4-2 Réseau LAN (isolé, sans NAT ni DHCP libvirt)
    - 4-3 Réseau DMZ (isolé)
    - 4-4 Vérification des réseaux créés
5. Déploiement et installation de la VM OPNsense
    - 5-1 Création de la VM avec trois interfaces réseau
    - 5-2 Attribution des interfaces réseau
    - 5-3 Configuration IP minimale en console
6. Installation des machines Debian (LAN et DMZ)
    - 6-1 Création de la VM Debian LAN
    - 6-2 Première connexion et vérifications
    - 6-3 Création de la VM Debian DMZ (machine hôte Docker)
7. Configuration d'OPNsense via l'interface web
    - 7-1 Assistant de configuration initiale
    - 7-2 Déclaration de l'interface DMZ (OPT1)
    - 7-3 Activation du serveur DHCP sur le LAN et la DMZ
    - 7-4 Vérification du NAT

8. Règles de pare-feu (principe du moindre privilège)
    - 8-1 Anatomie d'une règle de pare-feu
    - 8-2 Règles sur l'interface LAN
    - 8-3 Règles sur l'interface DMZ
    - 8-4 Règles sur l'interface WAN
    - 8-5 Port Forward
9. VPN IPsec nomade
    - 9-1 Rappel des concepts
    - 9-2 Activation du service IPsec sur OPNsense
    - 9-3 Pool d'adresses et paramètres du profil mobile
    - 9-4 Création d'un utilisateur VPN
    - 9-5 Phase 1 et Phase 2 côté serveur
    - 9-6 Règle de pare-feu pour le VPN
    - 9-7 Configuration du client (VM Kali sur wan-net)
10. Environnement Docker en DMZ
    - 10-1 Installation de Docker Engine et Docker Compose
    - 10-2 Création des fichiers du projet
    - 10-3 Démarrage et vérification
    - 10-4 Test de bout en bout (Internet → OPNsense → DMZ → Nginx → Front)

Conclusion

1- Introduction et Objectifs

Ce laboratoire a pour but de construire, de A à Z, une petite infrastructure d'entreprise virtualisée et sécurisée, en utilisant uniquement des outils gratuits sous Linux (Ubuntu + QEMU/KVM). Chaque outil, chaque commande et chaque écran d'installation est expliqué avant d'être utilisé.

À la fin du lab, nous aurons :

- Un pare-feu OPNsense routant trois zones réseau : WAN (Internet simulé), LAN (réseau interne des employés) et DMZ (zone démilitarisée hébergeant les services exposés).

- Des règles de pare-feu conformes aux bonnes pratiques (principe du moindre privilège, cloisonnement DMZ/LAN).

- Un accès VPN IPsec nomade (« road warrior ») permettant à un employé distant de rejoindre le LAN de façon chiffrée.

- Une application web conteneurisée (Nginx en reverse proxy + application « front ») exposée depuis la DMZ vers Internet.

Pourquoi OPNsense plutôt que FortiGate ?

FortiGate nécessite une licence/image propriétaire difficile à obtenir légalement pour un usage personnel. OPNsense est open-source, gratuit, très proche en fonctionnalités (règles de pare-feu par interface, NAT, IPsec, VPN) et s'installe parfaitement sous QEMU/KVM. Les concepts appris sont directement transposables à FortiGate/pfSense : seuls les noms de menus changent.

2- Concepts clés à comprendre avant de commencer

Cette section explique, en langage simple, tout le vocabulaire utilisé dans la suite du rapport.

2-1 Virtualisation, hyperviseur, machine virtuelle

- Machine virtuelle (VM)

Un ordinateur complet (CPU, RAM, disque, cartes réseau) entièrement simulé par logiciel à l'intérieur de votre PC réel. On peut en faire tourner plusieurs en même temps sur une seule machine physique, chacune isolée des autres.

- Hyperviseur

Le logiciel qui crée et gère les machines virtuelles. Il existe deux types : type 1 (« bare metal », installé directement sur le matériel, ex. VMware ESXi) et type 2 (installé au-dessus d'un système d'exploitation existant, ex. VirtualBox). KVM, que nous utilisons ici, est un hyperviseur de type 1 intégré au noyau Linux, piloté depuis votre Ubuntu comme s'il était de type 2 le meilleur des deux mondes en termes de performance.

- Hôte / invité (host / guest)

L'« hôte » est votre machine physique Ubuntu. L'« invité » est chaque machine virtuelle qui tourne dessus (OPNsense, Debian, Kali...).

2-2 Qemu, KVM, libvirt, virt-manager

Ces quatre noms désignent des couches logicielles différentes qui travaillent ensemble.

- KVM : Module du noyau Linux qui permet au processeur d'exécuter du code d'une VM presque à vitesse native (utilise les extensions de virtualisation matérielle Intel VT-x / AMD-V).

- QEMU : Le logiciel qui émule le matériel virtuel (carte réseau, disque, carte graphique...) d'une VM. Combiné à KVM, on parle de « QEMU/KVM ».

- libvirt : Une couche de gestion (démon libvirtd + API) qui pilote QEMU/KVM de façon standardisée : créer des VM, des réseaux virtuels, des disques, etc. C'est ce que virsh et virt-manager utilisent en coulisses.

- virt-manager : L'interface graphique (GUI) qui permet de créer/gérer des VM sans taper de commandes.

- virsh / virt-install : Les outils en ligne de commande équivalents à virt-manager, pratiques pour automatiser ou documenter précisément une configuration (c'est ce que nous utiliserons principalement dans ce guide, car reproductible).

2-3 Réseaux virtuels : bridge, NAT , réseau isolé

Une VM a besoin d'au moins une carte réseau virtuelle pour communiquer. libvirt propose plusieurs modes de réseau virtuel :

Réseau NAT

Les VM connectées à ce réseau peuvent sortir vers Internet (via l'adresse IP de l'hôte, traduite/masquée), mais ne sont pas directement joignables depuis l'extérieur. C'est le mode utilisé par Kali actuellement, et celui que nous utiliserons pour simuler le WAN/Internet.

Réseau isolé (isolated)

Un réseau purement interne : les VM connectées dessus communiquent entre elles et avec l'hôte, mais n'ont AUCUN accès à Internet et ne sont PAS routées automatiquement. C'est ce que nous utiliserons pour le LAN et la DMZ : seul OPNsense (qui aura une carte réseau sur chacun de ces réseaux) pourra faire transiter et filtrer le trafic entre eux.

Bridge (pont réseau)

Un commutateur virtuel logiciel auquel se connectent les cartes réseau des VM d'un même réseau libvirt, un peu comme un switch physique reliant plusieurs câbles Ethernet.

2-4 Pare-feu et zones réseau : WAN, LAN, DMZ

Pare-feu (firewall)

Un équipement (ici, une VM OPNsense) qui examine tout le trafic réseau passant par lui et décide de l'autoriser ou de le bloquer, selon des règles définies par l'administrateur. C'est aussi souvent un routeur : il relie plusieurs réseaux entre eux.

WAN (Wide Area Network)

L'interface "côté extérieur" du pare-feu, connectée à Internet (ou ici, à un réseau qui simule Internet).

LAN (Local Area Network)

Le réseau interne de confiance, où se trouvent les postes des employés.

DMZ (DeMilitarized Zone / zone démilitarisée)

Un réseau intermédiaire, ni totalement "dehors" ni totalement "dedans", où l'on place les serveurs qui doivent être accessibles depuis Internet (ex. un site web). L'idée : si un serveur de la DMZ est piraté, l'attaquant ne doit pas pouvoir rebondir vers le LAN, où se trouvent les données sensibles des employés.

Règle de pare-feu (filtre)

Une instruction du type « autoriser/bloquer le trafic venant de telle source, vers telle destination, sur tel port, sur telle interface ». Les règles sont évaluées dans l'ordre, la première qui correspond au trafic s'applique. S'il n'y a aucune correspondance, la politique par défaut (généralement « tout bloquer ») s'applique.

NAT (Network Address Translation)

Technique qui permet de faire correspondre des adresses IP privées (comme 10.10.10.0/24) à une adresse IP publique unique pour sortir sur Internet (« NAT sortant » / masquerading), ou inversement de rediriger un port public vers une machine interne (« NAT de destination » / port forwarding).

DHCP (Dynamic Host Configuration Protocol)

Service qui distribue automatiquement une adresse IP (et la passerelle, le DNS...) à chaque machine qui se connecte au réseau, pour éviter de configurer chaque poste manuellement.

2-5 VPN et Ipsec

VPN (Virtual Private Network)

Un tunnel chiffré qui permet à une machine distante (ex. l'ordinateur d'un employé en télétravail) de rejoindre virtuellement un réseau privé (le LAN de l'entreprise) comme si elle y était physiquement branchée, en passant par un réseau non fiable (Internet).

IPsec

Un ensemble de protocoles standardisés pour créer des VPN chiffrés et authentifiés. Il fonctionne en deux phases : la Phase 1 (IKE) établit un canal sécurisé entre les deux extrémités et les authentifie mutuellement ; la Phase 2 négocie les clés de chiffrement du trafic réel (protocole ESP) qui va circuler dans le tunnel.

Road warrior / accès nomade / remote access

Un mode de VPN où le poste distant ("nomade") n'a pas d'adresse IP fixe connue à l'avance (contrairement à un tunnel site-à-site entre deux bureaux fixes) : c'est le pare-feu qui accepte les connexions entrantes de clients mobiles authentifiés par identifiant/mot de passe ou certificat.

2-6 Docker, conteneurs et reverse proxy

Conteneur

Un environnement applicatif léger et isolé, qui partage le noyau Linux de la machine hôte (contrairement à une VM qui simule un ordinateur entier). Un conteneur démarre en une seconde et consomme très peu de ressources.

Image Docker

Le "plan" figé d'un conteneur : un ensemble de fichiers (système, dépendances, code de l'application) à partir duquel un ou plusieurs conteneurs peuvent être lancés. On construit une image avec un Dockerfile.

Dockerfile

Un fichier texte listant les instructions pour construire une image Docker pas à pas (ex. « pars de l'image nginx, copie mes fichiers HTML dedans »).

Docker Compose

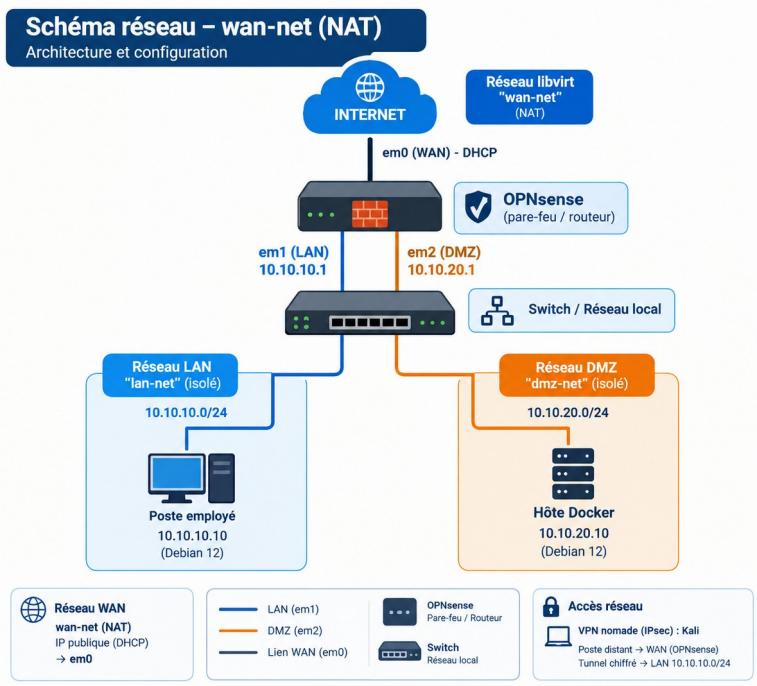
Un outil qui permet de décrire, dans un seul fichier docker-compose.yml, plusieurs conteneurs (services) et la façon dont ils communiquent entre eux, puis de tous les démarrer/arrêter en une seule commande.

Reverse proxy

Un serveur (ici Nginx) placé devant une ou plusieurs applications, qui reçoit toutes les requêtes entrantes et les redistribue vers la bonne application interne. Il permet d'exposer un seul point d'entrée public (port 80/443) tout en gardant les applications elles-mêmes non exposées directement.

3- Architecture cible

3-1 Schéma logique



Ce schéma représente une architecture réseau basée sur OPNsense, qui joue le rôle de pare-feu et de routeur. OPNsense possède trois interfaces : em0 (WAN) connectée à Internet via le réseau wan-net en NAT et DHCP, em1 (LAN) avec l'adresse 10.10.10.1, et em2 (DMZ) avec l'adresse 10.10.20.1. Le réseau LAN 10.10.10.0/24 héberge un poste employé sous Debian 13 (10.10.10.10), tandis que le réseau DMZ 10.10.20.0/24 héberge un serveur Debian 13 avec Docker (10.10.20.10), destiné notamment aux services comme Nginx et le frontend. La séparation entre LAN et DMZ permet à OPNsense de contrôler et filtrer les communications entre les différents réseaux. Enfin, un poste Kali distant peut se connecter au réseau interne grâce à un tunnel VPN IPsec chiffré établi avec OPNsense, permettant un accès sécurisé aux ressources autorisées du LAN.

3-2 Plan d'adressage IP

Zone	**Réseau libvirt**	**Sous-réseau**	**Passerelle (OPNsense)**	**Hôtes**
WAN	wan-net (mode NAT)	192.168.100.0/24 (DHCP)	192.168.100.1 (routeur libvirt)	OPNsense WAN : DHCP
LAN	lan-net (isolé)	10.10.10.0/24	10.10.10.1	Debian LAN : 10.10.10.10
DMZ	dmz-net (isolé)	10.10.20.0/24	10.10.20.1	Debian DMZ : 10.10.20.10
VPN Nomade	pool IPsec (virtuel)	10.10.30.0/24	10.10.30.1	Clients mobiles (Kali)

La DMZ et le LAN sont deux réseaux isolés distincts créés par libvirt : ils ne communiquent JAMAIS directement entre eux au niveau 2 (câblage virtuel). Tout le trafic inter-zones passe obligatoirement par OPNsense, qui applique les règles de pare-feu.

3-3 Ressources rcommandées pour chaque VM

VM	**vCPU**	**RAM**	**Disque**
OPNsense	2	2 Go (4 Go conseillé)	20 Go
Debian LAN	1	1 Go	10 Go
Debian DMZ (Docker)	2	2 Go	20 Go
Kali (déjà présente)	2	2-4 Go	40 Go

Total recommandé : environ 9-10 Go de RAM disponible si toutes les VM tournent en même temps

4- Création des réseaux virtuels

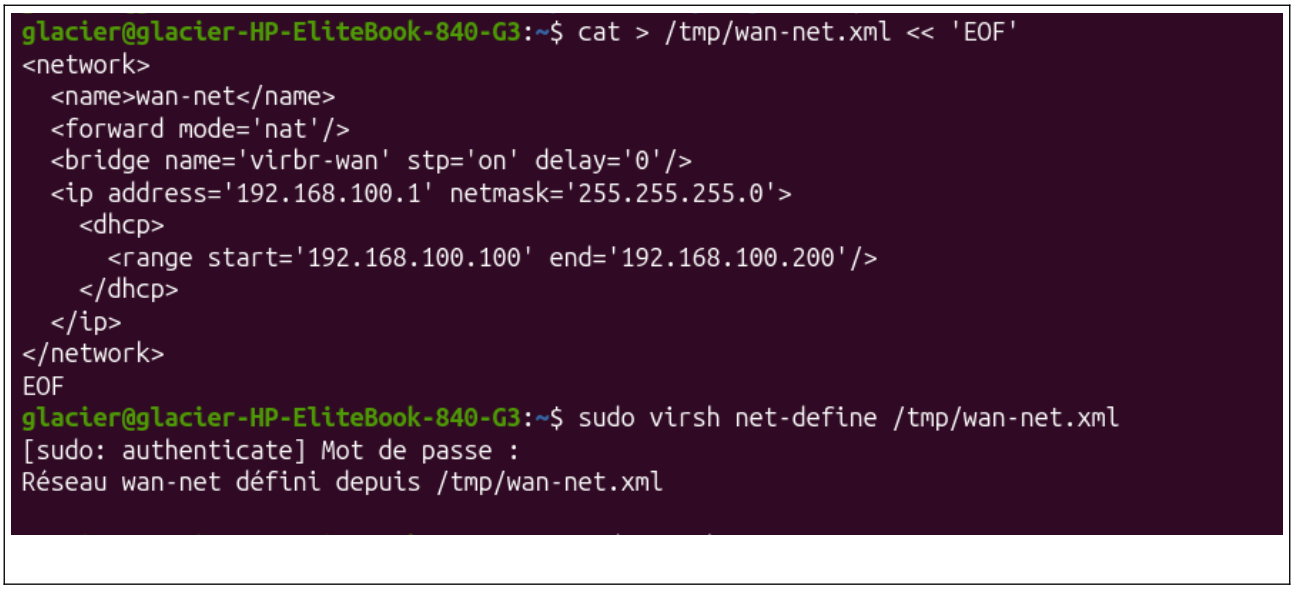
Nous créons trois réseaux virtuels distincts. wan-net simule Internet (mode NAT : les VM connectées dessus peuvent sortir sur le web via notre connexion Ubuntu). lan-net et dmz-net sont « isolés » : seules les VM branchées dessus se voient entre elles, et rien ne sort automatiquement ; c'est volontaire, car seul OPNsense doit décider ce qui peut transiter.

4-1 Réseau WAN (NAT)

Un réseau NAT par défaut (souvent nommé « default », 192.168.122.0/24) existe déjà sur notre hôte. nous créons un réseau NAT dédié nommé wan-net :

```
cat > /tmp/wan-net.xml << 'EOF'
<network>
  <name>wan-net</name>
  <forward mode='nat'/>
  <bridge name='virbr-wan' stp='on' delay='0'/>
  <ip address='192.168.100.1' netmask='255.255.255.0'>
    <dhcp>
      <range start='192.168.100.100' end='192.168.100.200'/>
    </dhcp>
  </ip>
</network>
EOF

sudo virsh net-define /tmp/wan-net.xml
sudo virsh net-autostart wan-net
sudo virsh net-start wan-net
```



Explication du fichier XML :

forward mode='nat' indique à libvirt de faire du NAT (masquerading) pour ce réseau les VM connectées sortiront via l'IP de l'hôte Ubuntu. Le bloc <dhcp> fait que libvirt distribue lui-même des adresses IP 192.168.100.100-200 aux VM connectées à ce réseau (ce sera le cas d'OPNsense côté WAN, qui recevra son IP automatiquement, exactement comme le ferait un box Internet chez un vrai fournisseur d'accès).

4-2 Réseau LAN (isolé, sans NAT ni DHCP libvirt)

Ici, pas de bloc <forward> ni de <dhcp> : c'est ce qui rend le réseau « isolé ». Le DHCP pour ce réseau sera géré plus tard par OPNsense lui-même (comme le ferait un vrai pare-feu d'entreprise), pas par libvirt.

```
cat > /tmp/lan-net.xml << 'EOF'
<network>
  <name>lan-net</name>
  <bridge name='virbr-lan' stp='on' delay='0'/>
</network>
EOF

sudo virsh net-define /tmp/lan-net.xml
sudo virsh net-autostart lan-net
sudo virsh net-start lan-net
```



Ce code permet de **créer et configurer un réseau virtuel Libvirt appelé** lan-net. Il commence par créer le fichier /tmp/lan-net.xml, qui décrit le réseau et son bridge virtuel virbr-lan. Le protocole STP est activé afin de limiter les risques de boucles réseau. Ensuite, virsh net-define enregistre cette configuration dans Libvirt, virsh net-autostart lan-net configure le réseau pour démarrer automatiquement avec Libvirt, et enfin virsh net-start lan-net démarre immédiatement le réseau. Ainsi, lan-net devient disponible pour connecter les machines virtuelles du réseau LAN.

4-3 Réseau DMZ (isolé)

```
cat > /tmp/dmz-net.xml << 'EOF'
<network>
  <name>dmz-net</name>
  <bridge name='virbr-dmz' stp='on' delay='0'/>
</network>
EOF

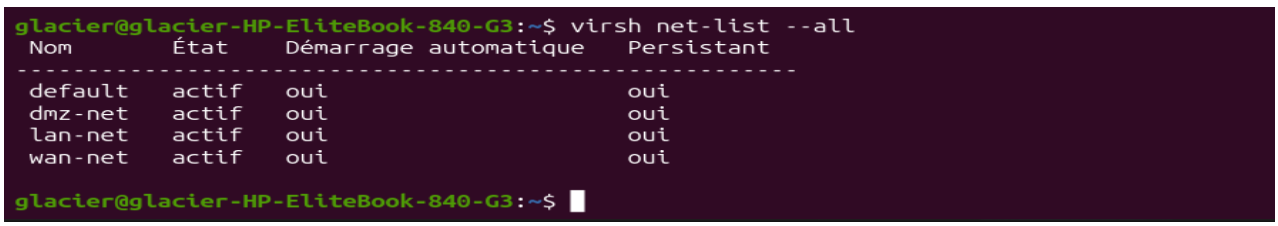
sudo virsh net-define /tmp/dmz-net.xml
sudo virsh net-autostart dmz-net
sudo virsh net-start dmz-net
```



Ce code permet de **créer et configurer un réseau virtuel Libvirt appelé** dmz-net, destiné à la **DMZ**. Il crée le fichier /tmp/dmz-net.xml, qui définit le réseau et son bridge virtuel virbr-dmz. Le paramètre stp='on' active le protocole STP pour éviter certaines boucles réseau, tandis que delay='0' indique qu'aucun délai supplémentaire n'est configuré. Ensuite, virsh net-define enregistre le réseau dans Libvirt, virsh net-autostart dmz-net configure son démarrage automatique, et virsh net-start dmz-net démarre immédiatement le réseau. Ainsi, dmz-net est prêt à connecter les machines virtuelles qui se trouvent dans la **zone DMZ**, séparée du réseau LAN.

4-4 Vérification des réseaux créés

```
virsh net-list --all
```



5- Déploiment et installation de la VM OPNsense

5-1 Création de VM avec trois (3) interfaces réseau

Nous utilisons virt-install pour créer directement la VM avec ses 3 cartes réseau (une par zone) : c'est plus fiable que d'en ajouter après coup, car l'ordre de détection par OPNsense correspond alors précisément à l'ordre de déclaration ci-dessous.

```
sudo virt-install \
  --name opnsense \
  --ram 4096 \
  --vcpus 2 \
  --cpu host \
  --disk path=/var/lib/libvirt/images/opnsense.qcow2,size=20,format=qcow2 \
  --cdrom /home/glacier/Documents/ISO/OPNsense-26.7-dvd-amd64.iso \
  --os-variant freebsd13.0 \
  --network network=wan-net,model=virtio \
  --network network=lan-net,model=virtio \
  --network network=dmz-net,model=virtio \
  --graphics vnc \
  --boot menu=on
```

Explication des options principales :

--ram / --vcpus : Mémoire et nombre de coeurs alloués à la VM.

--cpu host : Expose au maximum les fonctionnalités du CPU physique à la VM .

--disk ...size=20,format=qcow2 : Crée un nouveau disque virtuel de 20 Go, au format qcow2 (format natif QEMU, compressé et à allocation dynamique n'occupe réellement que l'espace utilisé).

--cdrom : Monte l'image ISO/IMG téléchargée comme un lecteur DVD virtuel, pour démarrer dessus et lancer l'installateur.

--os-variant freebsd13.0 : Indique à libvirt le système d'exploitation attendu (OPNsense est basé sur FreeBSD), pour optimiser certains réglages par défaut.

--network network= : Une ligne par carte réseau virtuelle ; l'ordre de ces lignes = l'ordre dans lequel OPNsense détectera vtnet0, vtnet1, vtnet2.

--graphics vnc : permet d'afficher l'écran de la VM (console graphique) via VNC, ce que virt-manager affiche automatiquement dans une fenêtre.

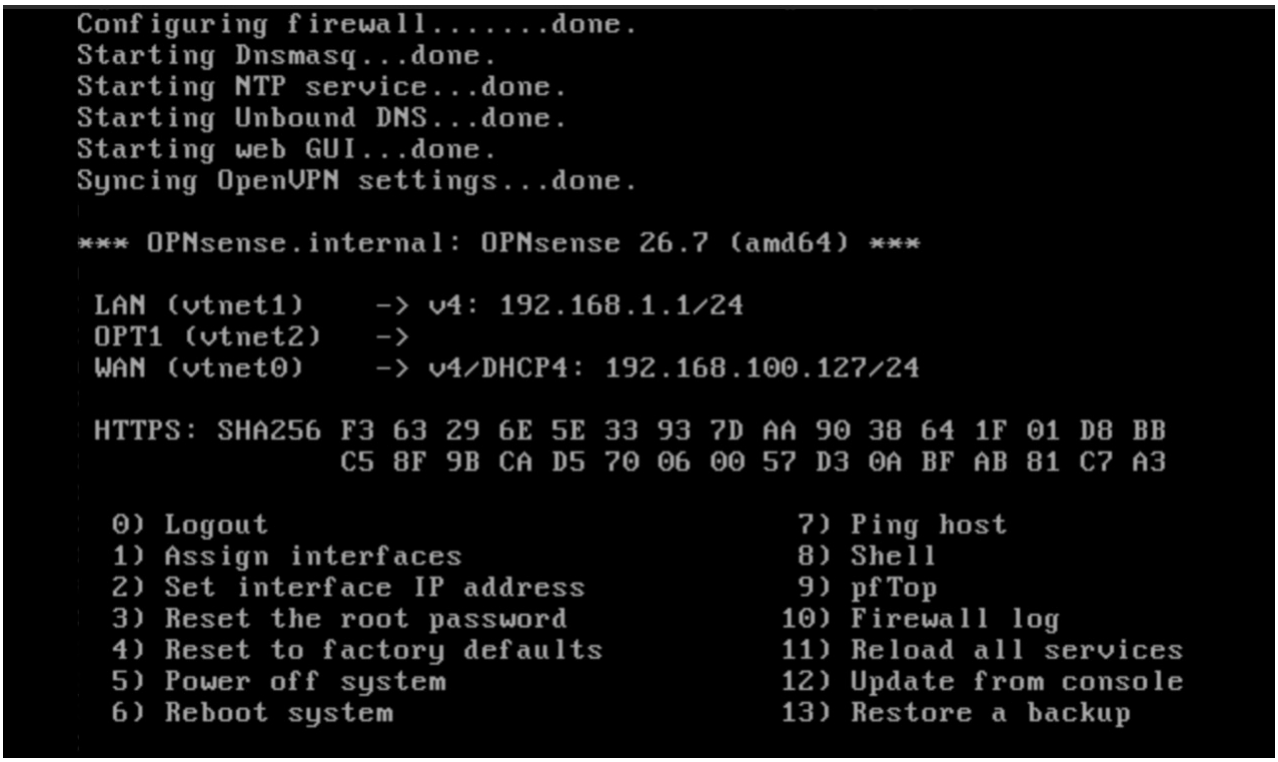
5-2 Attribution des interfaces réseau

Au premier démarrage après installation, OPNsense affiche un menu texte numéroté directement dans la console virt-manager. C'est ici que l'on indique quelle carte réseau virtuelle correspond à quelle zone :

Menu console OPNsense :
0) Logout
1) Assign interfaces
2) Set interface IP address
...

Choisissez '1) Assign interfaces'. L'installateur liste les interfaces détectées,
dans l'ordre où elles ont été déclarées dans virt-install :
vtnet0 -> carte connectée à wan-net
vtnet1 -> carte connectée à lan-net
vtnet2 -> carte connectée à dmz-net

Répondez aux questions posées :
'Do you want to configure LAGGs now? [y/N]' -> n
'Do you want to configure VLAN interfaces now? [y/N]' -> n
'Enter the WAN interface name' -> vtnet0
'Enter the LAN interface name' -> vtnet1
'Enter the Optional interface 1 name (or 'a' for all)' -> vtnet2
(laisser vide puis Entrée pour terminer la liste)
'Do you want to proceed? [y/N]' -> y

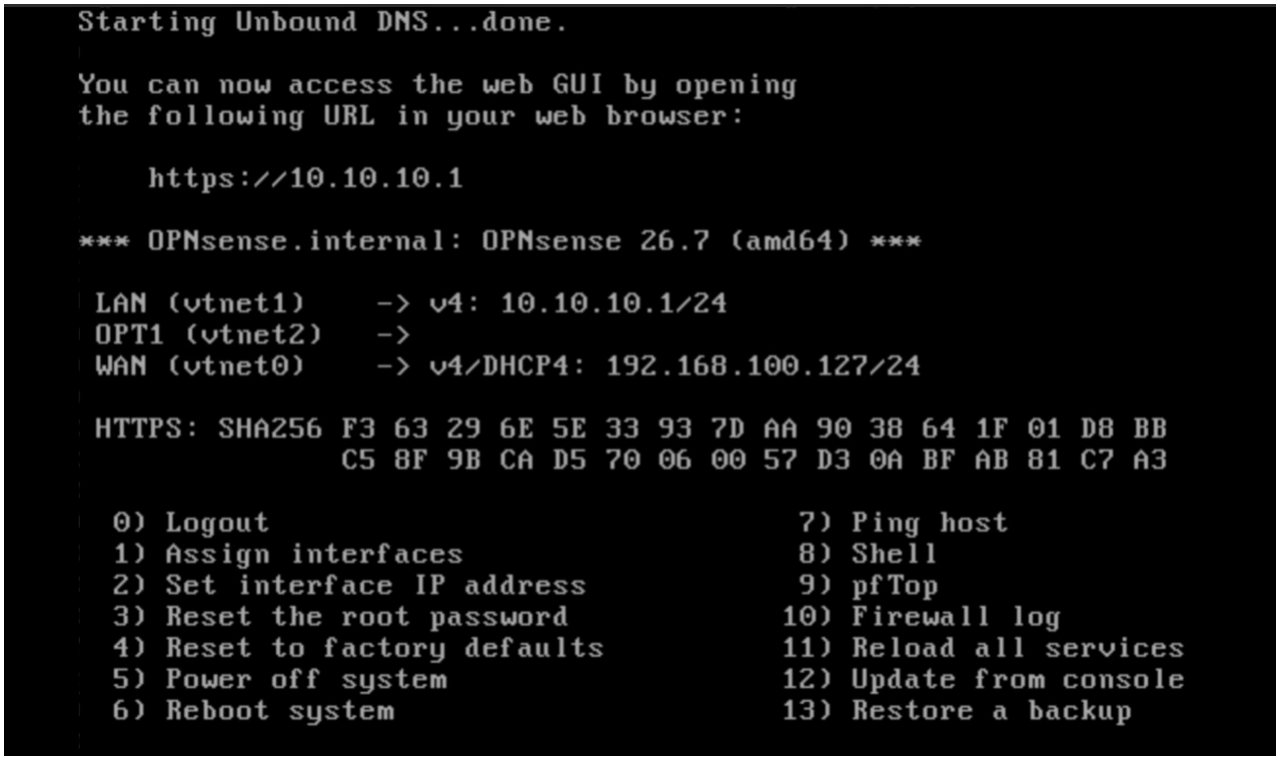


L'interface « Optional 1 » (OPT1) correspondra à notre DMZ ; nous la renommerons « DMZ » plus tard dans l'interface web

5-3 Configuration ip minimale en console

Toujours dans le menu console, choisissez l'option « 2) Set interface IP address » pour définir l'adresse LAN (indispensable pour ensuite atteindre l'interface web) :

Sélectionnez l'interface LAN, puis répondez :
'Configure IPv4 address LAN interface via DHCP? [y/N]' n
'Enter the new LAN IPv4 address' 10.10.10.1
'Enter the new LAN IPv4 subnet bit count' 24
'For a WAN, enter the new LAN IPv4 upstream gateway address' -> (laisser vide, Entrée)
'Configure IPv6 address LAN interface via DHCP6? [y/N]' n
'Enter the new LAN IPv6 address' -> (laisser vide, Entrée)
'Do you want to enable the DHCP server on LAN? [y/N]' y
'Enter the start address of the IPv4 client address range' 10.10.10.100
'Enter the end address of the IPv4 client address range' 10.10.10.200
'Do you want to revert to HTTP as the webConfigurator protocol? [y/N]' n



Accès à l'interface web d'administration

Une fois cette étape terminée, l'interface web d'OPNsense sera joignable à l'adresse https://10.10.10.1 depuis n'importe quelle machine connectée au réseau lan-net.

6– Installation des machines debian (LAN et DMZ)

6-1 Création de la VM Debian LAN

L'installateur Debian se déroule en mode texte (« Install » plutôt que « Graphical install », plus léger et suffisant).

Écran	**Ce qu'il faut faire**
Choisissez « Install »	Écran de démarrage : sélectionnez « Install » (installation en mode texte) avec les flèches, puis Entrée.
Sélection de la langue	Choisissez « French »
Sélection du pays	France (ou votre pays réel utilisé pour les fuseaux horaires et miroirs).
Disposition du clavier	Français (ou votre disposition physique réelle).
Détection du matériel réseau	Automatique, aucune action requise.
Configuration réseau nom de la machine (hostname)	debian-lan (pour la VM LAN) ou debian-dmz (pour la VM DMZ).
Nom de domaine	lab.local
Mot de passe root	Choisissez un mot de passe
Création d'un utilisateur standard	Nom complet, identifiant et mot de passe. Cet utilisateur pourra utiliser sudo si nous cochons l'option ou ajouterons le au groupe sudo manuellement après
Configuration de l'horloge	Choisissez votre fuseau horaire (Paris).
Partitionnement des disques	Choisissez « Assisté utiliser un disque entier », puis sélectionnez l'unique disque virtuel proposé, puis « Tout dans une seule partition (recommandé pour les débutants) », puis « Terminer le partitionnement et appliquer les changements », puis confirmez « Oui ».
Analyse d'un autre CD ou DVD	Non.
Miroir Debian	Oui, utilisez un miroir réseau ; choisissez le pays puis un miroir (deb.debian.org), laissez le proxy HTTP vide si vous n'en avez pas.
Participation au sondage de popularité	Non (facultatif, sans importance pour le lab).
Sélection des logiciels (tasksel)	Décochez « Environnement de bureau » et « GNOME » si coché (pour rester léger). Cochez uniquement « SSH server » et « Utilitaires usuels du système ».
Installation du programme d'amorçage GRUB	Oui, installez GRUB sur le disque principal (/dev/vda).
Fin de l'installation	L'installateur éjecte le média et propose de redémarrer : validez.

6-2 Première connexion et vérifications

Passer root (ou utiliser sudo si l'utilisateur a été ajouté au groupe sudo)

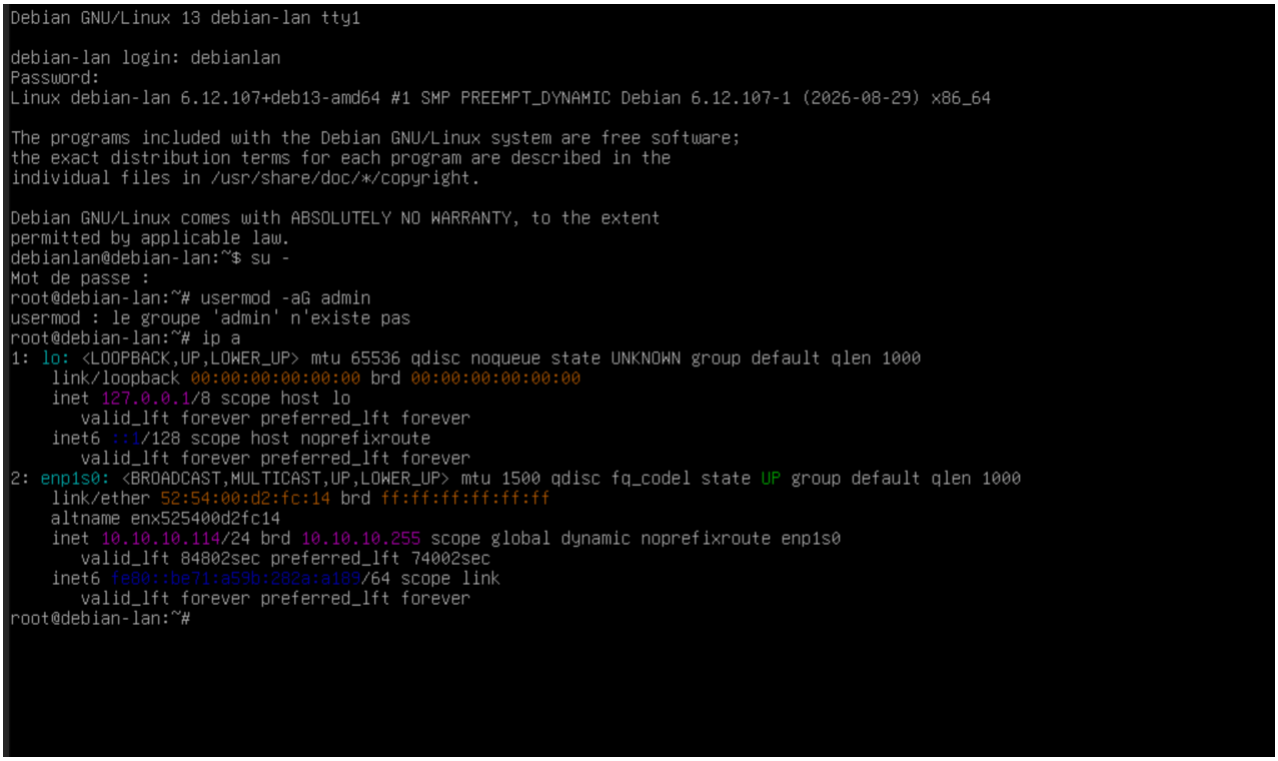
su -

Si besoin, ajouter votre utilisateur au groupe sudo :

usermod -aG sudo admin

Vérifier l'adresse IP obtenue

ip a



Si le DHCP d'OPNsense n'est pas encore actif au moment de cette installation (ce qui n’est pas le cas ici car nous voyons clairement que l’ip est dans la plage d’adresse définit sur le firewall mais nous allons par contre fixer l’ip de la machine pour notre lab), configurez une IP statique manuellement.

Éditer la configuration réseau (Debian 12 utilise ifupdown par défaut)

sudo nano /etc/network/interfaces

Remplacer le bloc de l'interface principale par :

auto enp1s0

iface enp1s0 inet static

address 10.10.10.10

netmask 255.255.255.0

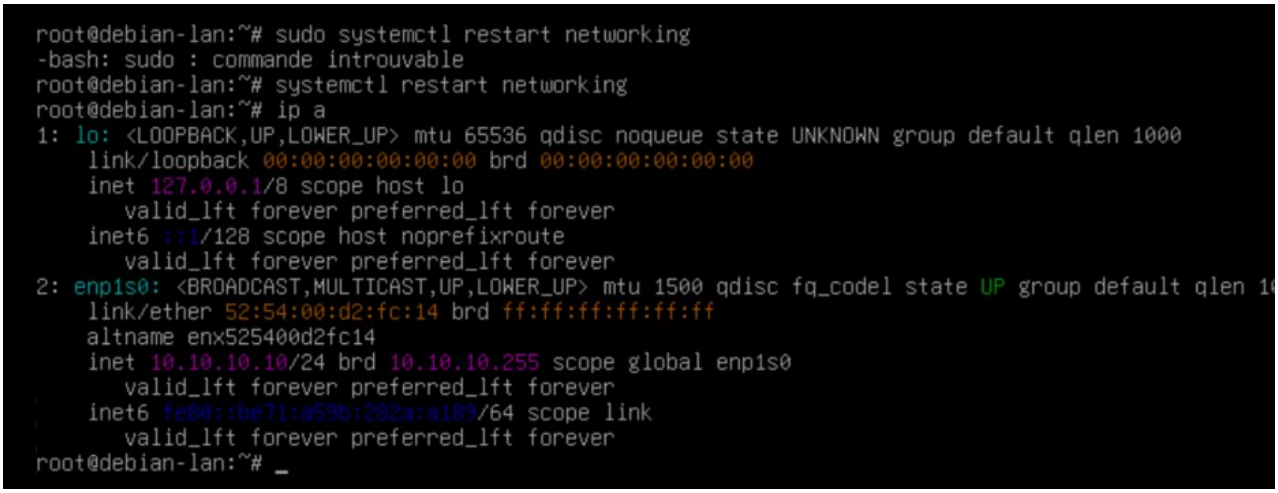
gateway 10.10.10.1

dns-nameservers 10.10.10.1

Puis redémarrer le réseau

sudo systemctl restart networking

ip a



6-3 Création de la VM Debian DMZ (comme machine hôte Docker)

```
sudo virt-install \
  --name debian-dmz \
  --ram 2048 \
  --vcpus 2 \
  --disk path=/var/lib/libvirt/images/debian-dmz.qcow2,size=20,format=qcow2 \
  --cdrom /home/glacier/Documents/ISO/debian-13.7.0-amd64-netinst.iso \
  --os-variant debian12 \
  --network network=dmz-net,model=virtio \
  --graphics vnc
```

Ici on répéte exactement la même procédure pour créer une seconde VM Debian, connectée cette fois à dmz-net :

Paramètre	**Debian LAN**	**Debian DMZ**
Adresse IP	10.10.10.10	10.10.20.10
Masque	255.255.255.0	255.255.255.0
Passerelle	10.10.10.1	10.10.20.1
DNS	10.10.10.1	10.10.20.1

7- Configuration d'OPNsense via l'interface web

L'option la plus simple est d'installer un petit environnement graphique et Firefox sur debian-lan avec la commande :

```
sudo apt install -y xfce4 firefox-esr
startx
```

ou d'ajouter temporairement une seconde carte réseau wan-net à debian-lan le temps de la première configuration.

7-1 Assistance de configuration initiale

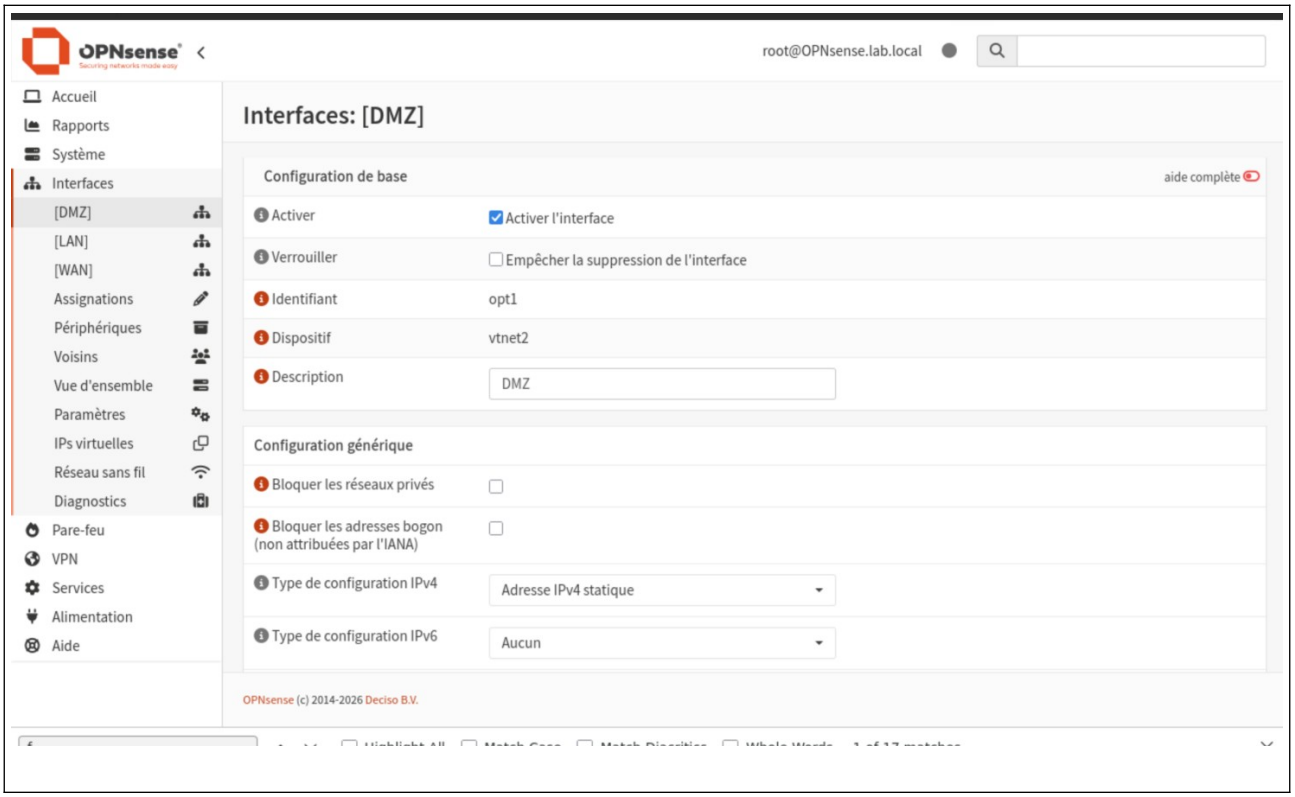
Écran	**Valeurs à saisir**
General Information	Hostname : opnsense Domain : lab.local DNS servers : 1.1.1.1 et 8.8.8.8 (décochez « Allow DNS server list to be overridden by DHCP/PPP on WAN » si vous voulez forcer ces DNS).
Time server information	Fuseau horaire : senegal/dakar.
Configure WAN Interface	Laissez « DHCP » (déjà obtenu automatiquement via wan-net). Décochez « Block RFC1918 private networks » si votre wan-net utilise une plage privée (c'est le cas ici avec

	192.168.100.0/24) sinon OPNsense bloquerait son propre WAN.
Configure LAN Interface	IPv4 address : 10.10.10.1 / 24 (déjà défini en console, vérifiez juste que c'est correct).
Set Admin WebGUI Password	Définissez un nouveau mot de passe robuste pour le compte root de l'interface web
Reload configuration	Cliquez sur « Reload » pour appliquer, puis « Finish ».

7-2 Déclarer l'interface DMZ (OPT1)

Menu Interfaces, Assignments : vérifiez que vtnet2 apparaît bien en tant qu'« OPT1 ». Cliquez ensuite sur « OPT1 » dans le menu Interfaces (ou Interfaces [OPT1]) et configurez :

- Enable Interface : coché.
- Description : DMZ (renomme l'onglet, l'interface s'appellera désormais « DMZ » partout dans le menu).
- IPv4 Configuration Type : Static IPv4.
- IPv4 address : 10.10.20.1 / 24.
- Cliquez sur « Save » puis sur le bandeau orange « Apply Changes » en haut de page.



7-3 Activation du serveur DHCP sur le LAN et DMZ

Contexte : OPNsense 26.7 utilise le service Kea DHCP en remplacement de l'ancien ISC DHCP. La configuration se fait de manière centralisée (et non plus par onglet séparé par interface) via Services → Kea DHCP → Kea DHCPv4.

Étape 1 Activation générale du service

1. Aller dans Services → Kea DHCP → Kea DHCPv4.
2. Dans la section Service, cocher Activé.
3. Dans Paramètres généraux → Interfaces, sélectionner LAN et OPT1 (DMZ).
4. Cliquer sur Save.

Étape 2 Création du sous-réseau DHCP pour LAN

1. Aller dans l'onglet Subnets.
2. Cliquer sur + pour ajouter un sous-réseau.
3. Renseigner :
   - Sous-réseau : 10.10.10.0/24
   - Description : LAN
   - Piscines : 10.10.10.100-10.10.10.200
4. Cliquer sur Sauvegarder.

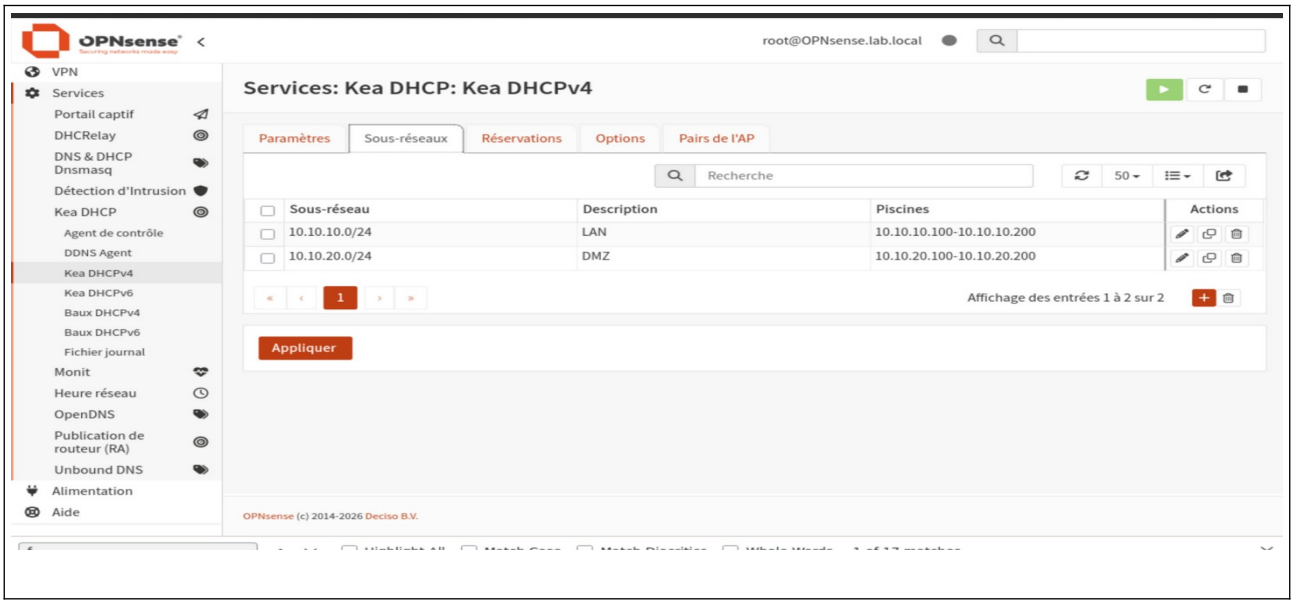
Étape 3 Création du sous-réseau DHCP pour DMZ

1. Répéter l'opération avec :
   - Sous-réseau : 10.10.20.0/24
   - Description : DMZ
   - Piscines : 10.10.20.100-10.10.20.200
2. Cliquer sur Sauvegarder.

Étape 4 Application des changements

1. Cliquer sur le bandeau orange Apply Changes en haut de la page pour appliquer la configuration au service Kea DHCP.

Résultat attendu : les machines virtuelles connectées aux réseaux lan-net et dmz-net reçoivent automatiquement une adresse IP dans leur plage respective (10.10.10.100–200 pour LAN, 10.10.20.100–200 pour DMZ) lors de leur prochain démarrage ou renouvellement de bail DHCP.



Adresses statiques vs DHCP pour les serveurs

Dans ce lab, nous fixons les adresses de debian-lan (10.10.10.10) et debian-dmz (10.10.20.10) manuellement plutôt que de les laisser recevoir une IP DHCP aléatoire, car nous devons créer des règles de pare-feu et un port forward pointant vers une adresse fixe et connue à l'avance. Le DHCP reste utile pour d'éventuels autres postes clients.

7-4 Vérification du NAT

Contexte : Le NAT sortant (Outbound NAT) permet aux adresses IP privées des réseaux internes (LAN et DMZ) d'accéder à Internet en étant automatiquement masquées derrière l'adresse IP publique de l'interface WAN d'OPNsense un mécanisme identique à celui utilisé par une box Internet grand public.

Étape 1 Accès au menu

1. Aller dans Pare-feu → NAT → NAT source (équivalent français de Firewall → NAT → Outbound).

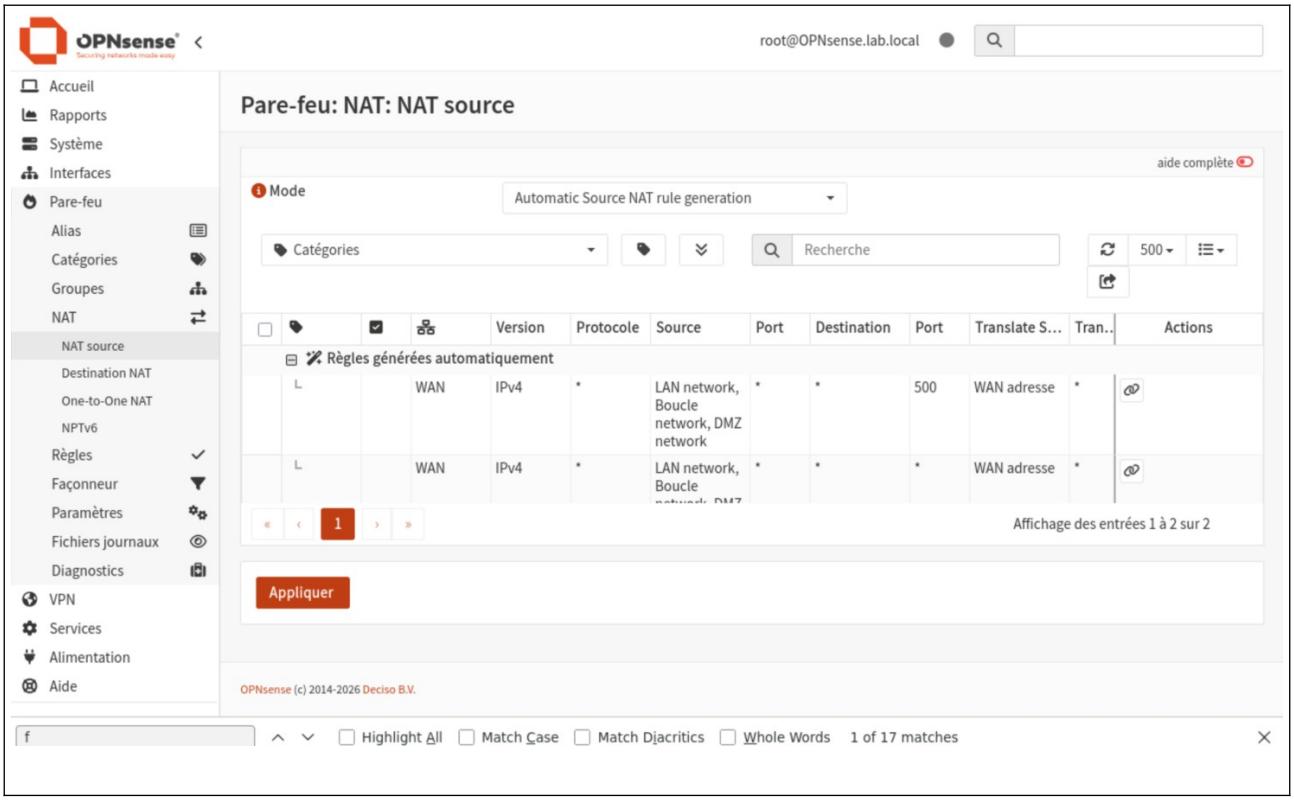
Étape 2 Vérification du mode

1. Vérifier que le champ Mode est bien réglé sur « Automatic Source NAT rule generation ».
2. Il s'agit du réglage par défaut d'OPNsense aucune modification n'est nécessaire.

Étape 3 Inspection des règles générées automatiquement

1. Déplier la section « Règles générées automatiquement » en cliquant sur le +.
2. Constater que des règles NAT sont automatiquement créées pour masquer le trafic sortant des réseaux LAN (10.10.10.0/24) et DMZ (10.10.20.0/24) derrière l'IP WAN d'OPNsense.

Résultat attendu : le NAT sortant automatique est actif par défaut et ne nécessite aucune configuration manuelle.



8- Règles de pare-feu (principe du moindre privilège)

8-1 Anatomie d’une règle de part-feu

Avant de créer les règles, comprenons leur structure. Dans OPNsense (comme sur la plupart des pare-feux, FortiGate inclus), chaque règle est rattachée à UNE interface et s'applique au trafic **ENTRANT** sur cette interface. Une règle est composée des champs suivants :

Action : Pass (autoriser), Block (bloquer silencieusement) ou Reject (bloquer en renvoyant une erreur).
Interface : Sur quelle interface le paquet doit arriver pour que la règle s'applique (ex. LAN).
Protocole : TCP, UDP, ICMP (ping), ou « any ».
Source : D'où vient le paquet (une adresse, un sous-réseau comme « LAN net », ou « any »).
Destination : Vers où va le paquet.
Port de destination : Le port applicatif visé (ex. 443 pour HTTPS, 22 pour SSH).

NB : les règles sont évaluées de haut en bas, et c'est la PREMIÈRE règle qui correspond au paquet qui s'applique (pas la plus précise, la première dans l'ordre d'affichage). Si aucune règle ne correspond, la politique implicite s'applique : « tout bloquer » (« deny all » implicite en bas de chaque interface, invisible dans la liste mais toujours actif). C'est cette politique par défaut restrictive qui garantit la sécurité : on n'autorise que ce qui est explicitement nécessaire.

Où créer les règles ?

Menu Firewall → Rules, puis choisir l'onglet correspondant à l'interface voulue (LAN, DMZ, WAN, IPsec...). Le bouton « + Add » en bas à droite de la liste crée une nouvelle règle.

8-2 Création des règles sur l’interface LAN

Contexte : Ces règles contrôlent ce que les machines du réseau LAN sont autorisées à initier vers les autres zones (OPNsense lui-même, la DMZ, Internet). Les règles sont évaluées de haut en bas ; la première correspondance s'applique. L'ordre ci-dessous doit donc être respecté.

Accès au menu : Pare-feu → Règles → LAN → « + »

Règle 1 Administration d'OPNsense depuis le LAN

Champ	Valeur
Action	Autoriser
Interface	LAN
Protocole	TCP
Source	LAN network
Destination	This Firewall (ce pare-feu)
Port de destination	HTTPS (443)
Description	Admin OPNsense depuis LAN

Règle 2 Administration SSH ponctuelle du serveur DMZ

Champ	Valeur
Action	Autoriser
Interface	LAN
Protocole	TCP
Source	LAN network
Destination	Hôte unique ou réseau → 10.10.20.10/32
Port de destination	SSH (22)
Description	Admin SSH LAN vers DMZ

Règle 3 Blocage du reste du trafic LAN → DMZ

Champ	Valeur
Action	Bloquer
Interface	LAN
Protocole	any
Source	LAN network
Destination	DMZ network
Port de destination	any
Description	Bloque reste LAN vers DMZ

Règle 4a Navigation web HTTP

Champ	Valeur
Action	Autoriser
Interface	LAN
Protocole	TCP
Source	LAN network
Destination	any
Port de destination	HTTP (80)
Description	Navigation web HTTP

Règle 4b Navigation web HTTPS

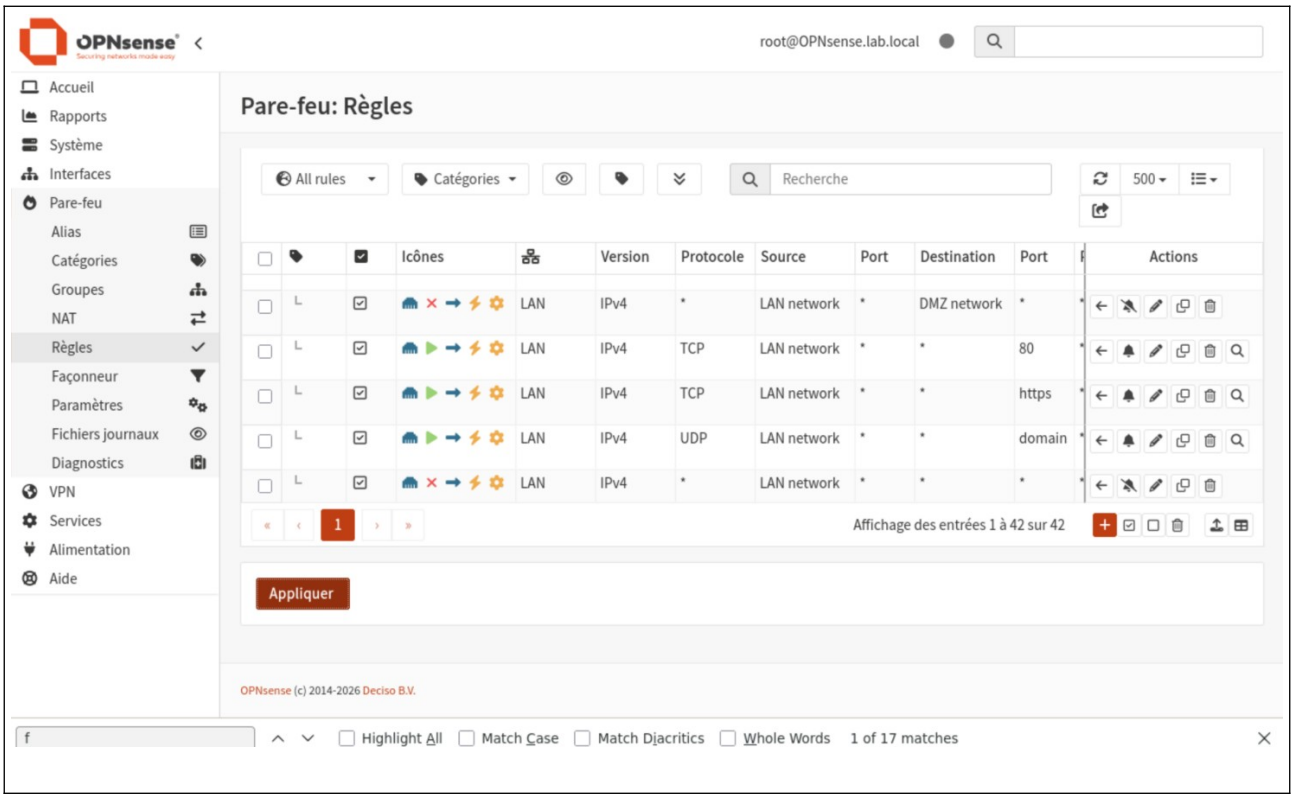
Champ	Valeur
Action	Autoriser
Interface	LAN
Protocole	TCP
Source	LAN network
Destination	any
Port de destination	HTTPS (443)
Description	Navigation web HTTPS

Règle 4c Résolution DNS

Champ	Valeur
Action	Autoriser
Interface	LAN
Protocole	UDP
Source	LAN network
Destination	any
Port de destination	DNS (53)
Description	Résolution DNS

Règle implicite Deny all

Aucune action requise : OPNsense applique automatiquement une règle de blocage final sur chaque interface, non modifiable et non affichée dans la liste.



8- 3 Règles sur l’interface DMZ

Contexte : Ces règles filtrent ce que les machines de la DMZ ont le droit d'initier. La DMZ est la zone la plus sensible du laboratoire car potentiellement exposée à des attaquants via un service web publié. Le principe de sécurité appliqué ici est celui du moindre privilège : la DMZ ne doit avoir accès qu'à Internet (pour ses mises à jour), et en aucun cas au réseau LAN. Si un serveur exposé en DMZ (donc plus vulnérable, car accessible depuis l'extérieur) est piraté, l'absence de lien vers le LAN empêche l'attaquant de rebondir vers ton réseau interne.

Accès au menu : Pare-feu → Règles → DMZ → « + »

Règle 1a Mises à jour système HTTP

Champ	Valeur
Action	Autoriser
Interface	DMZ
Protocole	TCP
Source	DMZ network
Destination	any
Port de destination	HTTP (80)
Description	Mises à jour système HTTP

Règle 1b Mises à jour système HTTPS

Champ	Valeur
Action	Autoriser
Interface	DMZ
Protocole	TCP
Source	DMZ network
Destination	any
Port de destination	HTTPS (443)
Description	Mises à jour système HTTPS

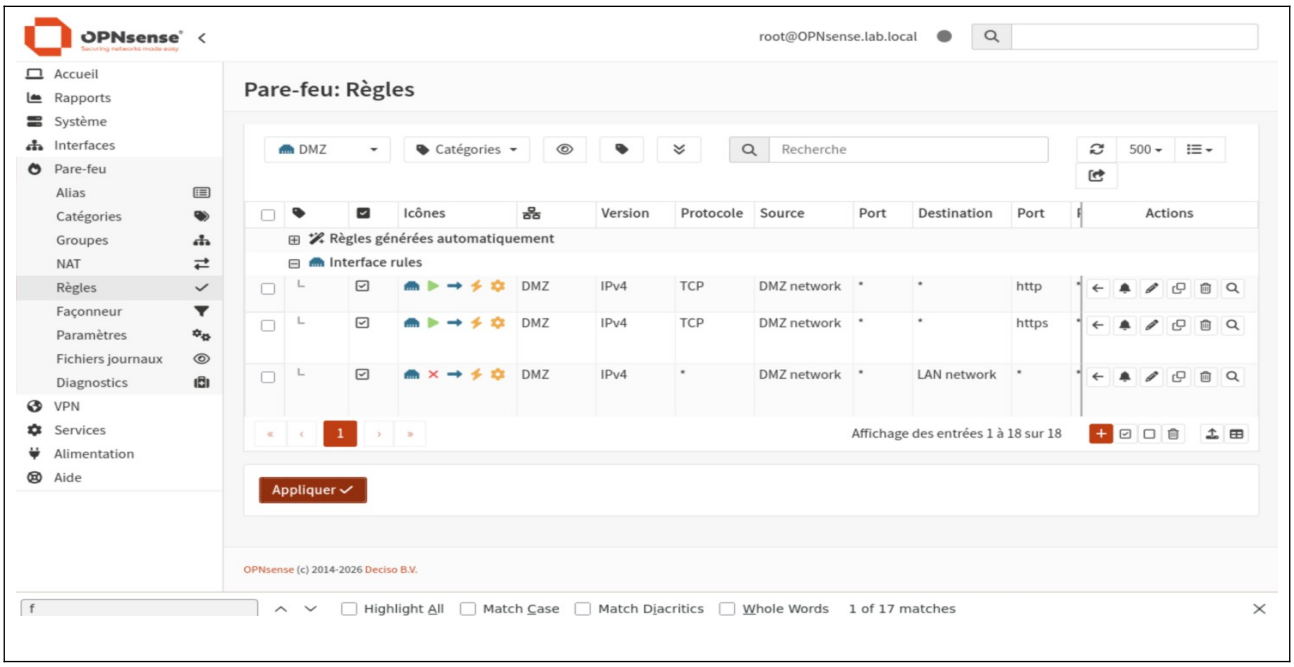
Règle 2 Blocage DMZ → LAN (règle de sécurité critique)

Champ	Valeur
Action	Bloquer
Interface	DMZ
Protocole	any
Source	DMZ network
Destination	LAN network
Port de destination	any
Description	Bloque DMZ vers LAN - isolation critique

Justification sécurité : cette règle matérialise le principe fondamental de la segmentation en DMZ. Sans elle, un attaquant compromettant le service web exposé en DMZ pourrait ensuite « rebondir » librement vers les postes de travail du réseau LAN interne. Elle constitue donc la règle la plus importante de l'ensemble du laboratoire d'un point de vue sécurité.

Règle implicite Deny all

Aucune action requise : OPNsense bloque automatiquement tout trafic non explicitement autorisé en fin de liste sur chaque interface.



8-4 Règles sur l'interface WAN

Contexte : Ces règles filtrent le trafic entrant depuis Internet. C'est la zone la plus critique du pare-feu : seul le strict nécessaire y est autorisé, afin de minimiser la surface d'attaque exposée publiquement.

Accès au menu : Pare-feu → Règles → WAN → « + »

Règle 1a VPN IPsec nomade : IKE

Champ	Valeur
Action	Autoriser
Interface	WAN
Protocole	UDP
Source	any
Destination	WAN address
Port de destination	500
Description	VPN IPsec - IKE

Règle 1b VPN IPsec nomade : NAT-Traversal

Champ	Valeur
Action	Autoriser
Interface	WAN
Protocole	UDP
Source	any
Destination	WAN address
Port de destination	4500
Description	VPN IPsec - NAT-Traversal

Règle 1c VPN IPsec nomade : ESP

Champ	Valeur
Action	Autoriser
Interface	WAN
Protocole	ESP
Source	any
Destination	WAN address
Port de destination	Non applicable (ESP ne dispose pas de ports)
Description	VPN IPsec - ESP

Remarque : ces trois règles couvrent ensemble l'ensemble de la négociation et du transport du tunnel IPsec (échange de clés via IKE, contournement du NAT, puis chiffrement des données via ESP).

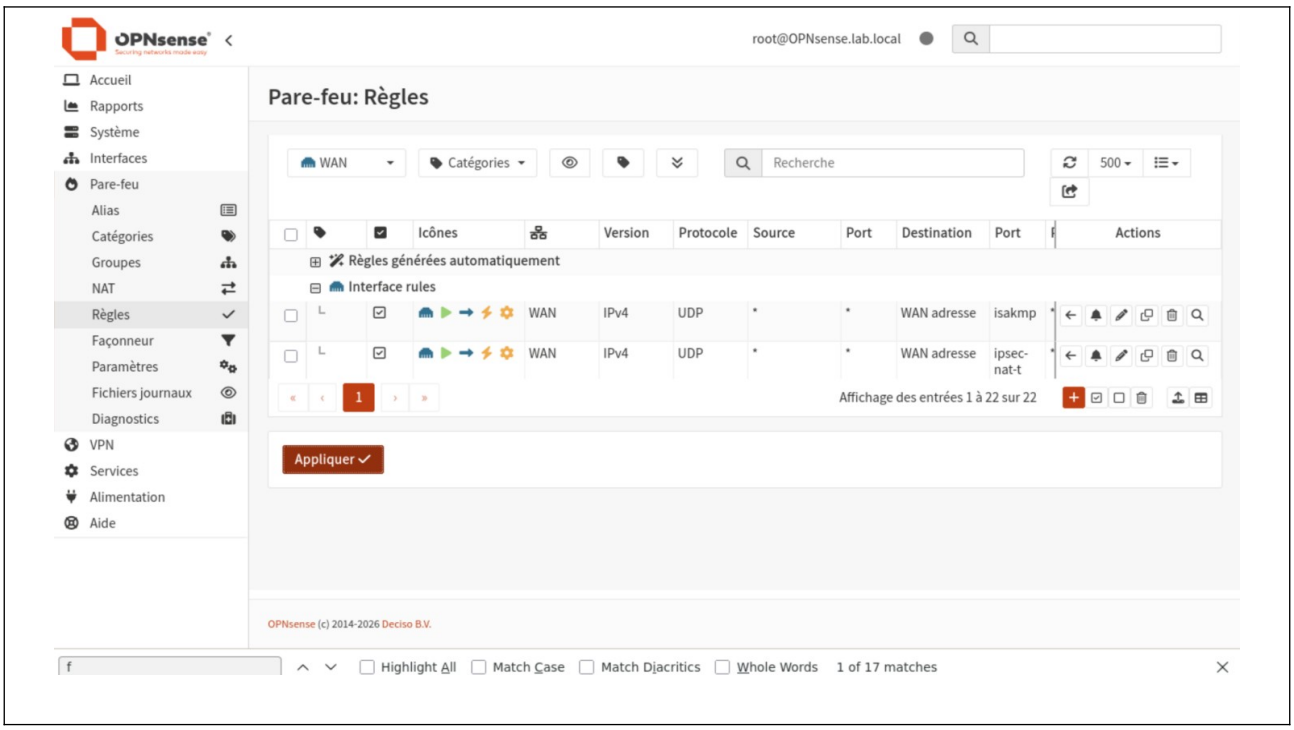
Règle 2 Redirection vers le reverse-proxy DMZ

Champ	Valeur
Action	Autoriser (générée automatiquement)
Source	any
Destination	10.10.20.10
Port de destination	TCP 80/443

Remarque importante : cette règle n'est pas créée manuellement. Elle est générée automatiquement par OPNsense lors de la configuration du Port Forward , à condition de cocher l'option « Add associated filter rule » durant cette configuration.

Règle implicite Deny all

Aucune action requise : OPNsense bloque automatiquement tout trafic entrant non explicitement autorisé, empêchant tout accès direct non filtré au réseau LAN depuis Internet.



La DMZ ne doit jamais pouvoir « remonter » vers le LAN : si le serveur web est compromis (ex. faille dans Nginx ou dans l'application front), l'attaquant reste cantonné à la DMZ. Le LAN, lui, doit pouvoir administrer la DMZ en SSH, mais pas l'inverse c'est une relation à sens unique. Le WAN ne doit exposer que les ports strictement nécessaires au fonctionnement du service (80/443) et du VPN (500/4500 + ESP) : c'est la surface d'attaque minimale.

8-5 Port Forward

Contexte : Un port forward redirige une requête arrivant sur l'interface WAN d'OPNsense vers une machine interne précise, ici le serveur Debian situé en DMZ. C'est le mécanisme qui permet de publier un service hébergé en interne (le reverse-proxy Nginx) tout en gardant le reste du réseau invisible depuis Internet.

Accès au menu : Pare-feu → NAT → Port Forward → « + Add »

Règle 1 Redirection HTTP (port 80)

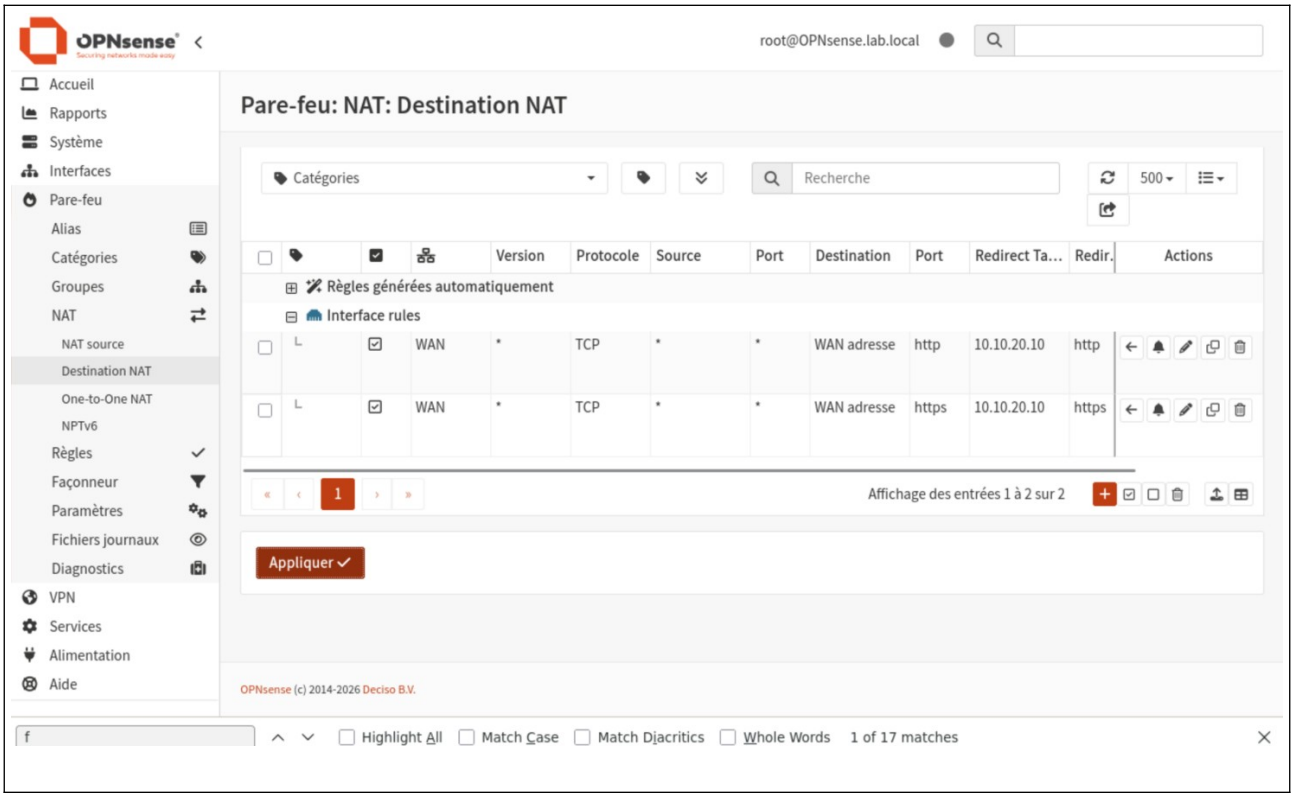
Champ	Valeur
Interface	WAN
Protocole	TCP
Destination	WAN address
Destination port range	de 80 à 80
Redirect target IP	10.10.20.10 (Debian DMZ)
Redirect target port	80
Description	Publication site web DMZ - HTTP
Filter rule association	Add associated filter rule

Règle 2 Redirection HTTPS (port 443)

Champ	Valeur
Interface	WAN
Protocole	TCP
Destination	WAN address
Destination port range	de 443 à 443
Redirect target IP	10.10.20.10 (Debian DMZ)
Redirect target port	443
Description	Publication site web DMZ - HTTPS
Filter rule association	Add associated filter rule

Fonctionnement de l'option « Add associated filter rule » : cette option génère automatiquement la règle de pare-feu WAN correspondante . Il n'est donc pas nécessaire de créer cette règle de filtrage manuellement en plus du port forward OPNsense synchronise les deux configurations (NAT et filtrage) en une seule opération.

Résultat attendu : toute requête HTTP ou HTTPS arrivant sur l'adresse IP WAN d'OPNsense est automatiquement redirigée vers le serveur Debian en DMZ (10.10.20.10), qui héberge le reverse-proxy Nginx.



9- VPN Ipsec nomade

Objectif : un employé situé « sur Internet » (simulé ici par le réseau wan-net, testé depuis la VM Kali) établit un tunnel IPsec IKEv2 vers OPNsense et obtient un accès direct au LAN 10.10.10.0/24, comme s'il était physiquement au bureau mais sans accès à la DMZ.

9-1 Rappel des concepts

- Phase 1 (IKE) : les deux extrémités (client Kali et OPNsense) s'authentifient mutuellement et négocient un canal de contrôle chiffré.
- Phase 2 (ESP) : à l'intérieur du canal établi en Phase 1, on négocie les clés qui chiffreront le trafic réel (les paquets IP échangés avec le LAN).
- EAP-MSCHAPv2 : méthode d'authentification par identifiant/mot de passe (plus simple à mettre en place pour un lab qu'une authentification par certificats client).

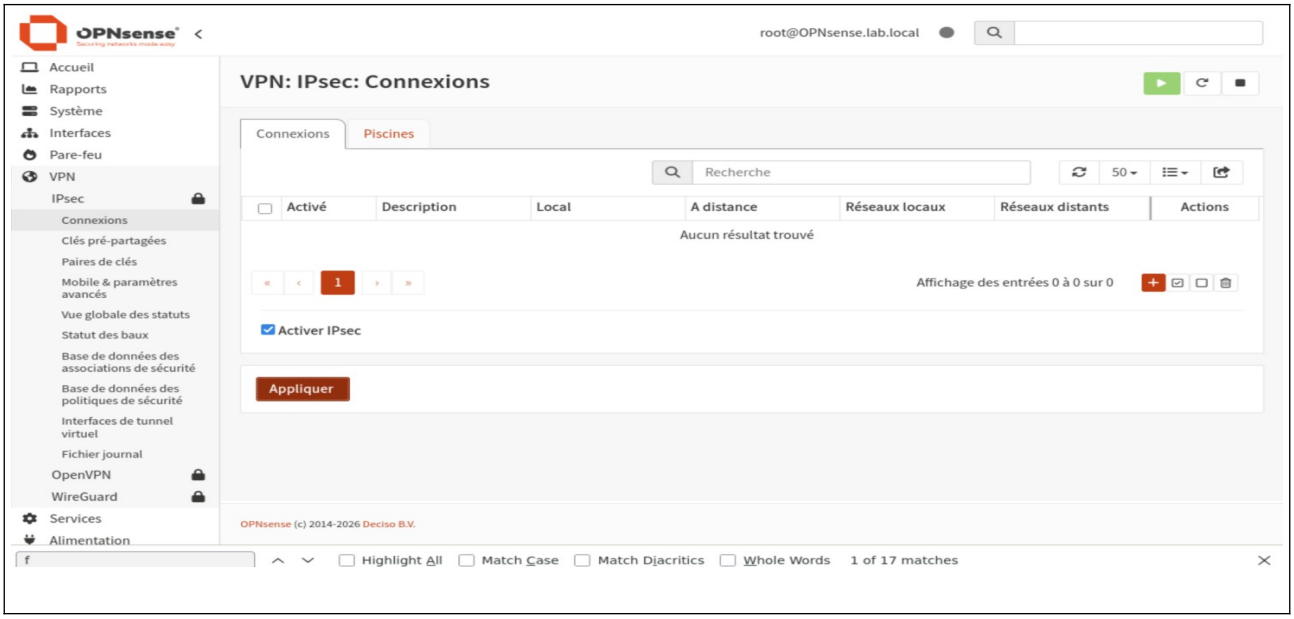
9-2 Activation du service Ipsec sur OPNsense

Objectif : IPsec (Internet Protocol Security) est une suite de protocoles qui chiffre et authentifie les communications au niveau IP. Sur OPNsense, le service IPsec est désactivé par défaut. Il faut l'activer globalement avant de pouvoir créer un tunnel VPN, ici le VPN nomade qui permet à un utilisateur distant d'accéder au réseau du laboratoire de façon sécurisée.

Procédure :

1. Se rendre dans le menu **VPN → IPsec → Connexions**.
2. Cocher la case **« Activer IPsec »**, située en bas de la page.
3. Cliquer sur le bouton **Appliquer** pour enregistrer et démarrer le service.

Résultat attendu : le service IPsec (démon strongSwan/Charon) est démarré sur OPNsense. Il écoute sur les ports UDP 500 (IKE) et UDP 4500 (NAT-Traversal), autorisés au préalable sur l'interface WAN. Il est alors prêt à recevoir la configuration des connexions VPN.



9-3 Pool d'adresses et paramètres du profil mobile

Objectif : définir comment les utilisateurs nomades se connectent au VPN : adresse virtuelle reçue, DNS utilisé, réseaux accessibles et méthode d'authentification.

Paramètre	Valeur
Virtual Address Pool	10.10.30.0/24
Serveur DNS poussé au client	10.10.10.1
Réseau local accessible	10.10.10.0/24 (LAN uniquement, jamais la DMZ)
Méthode d'authentification	IKEv2 avec EAP-MSCHAPv2 (utilisateur / mot de passe local)

Étape 1 : création de la piscine d'adresses virtuelles

Menu **VPN → IPsec → Connexions**, onglet **Piscines**, bouton **+**.

Champ	Valeur
Nom	Pool-Nomades
Réseau	10.10.30.0/24
DNS	10.10.10.1

Sauvegarder.

Les clients nomades recevront une adresse de cette plage et utiliseront 10.10.10.1 comme serveur DNS.

Étape 2 : création du certificat serveur

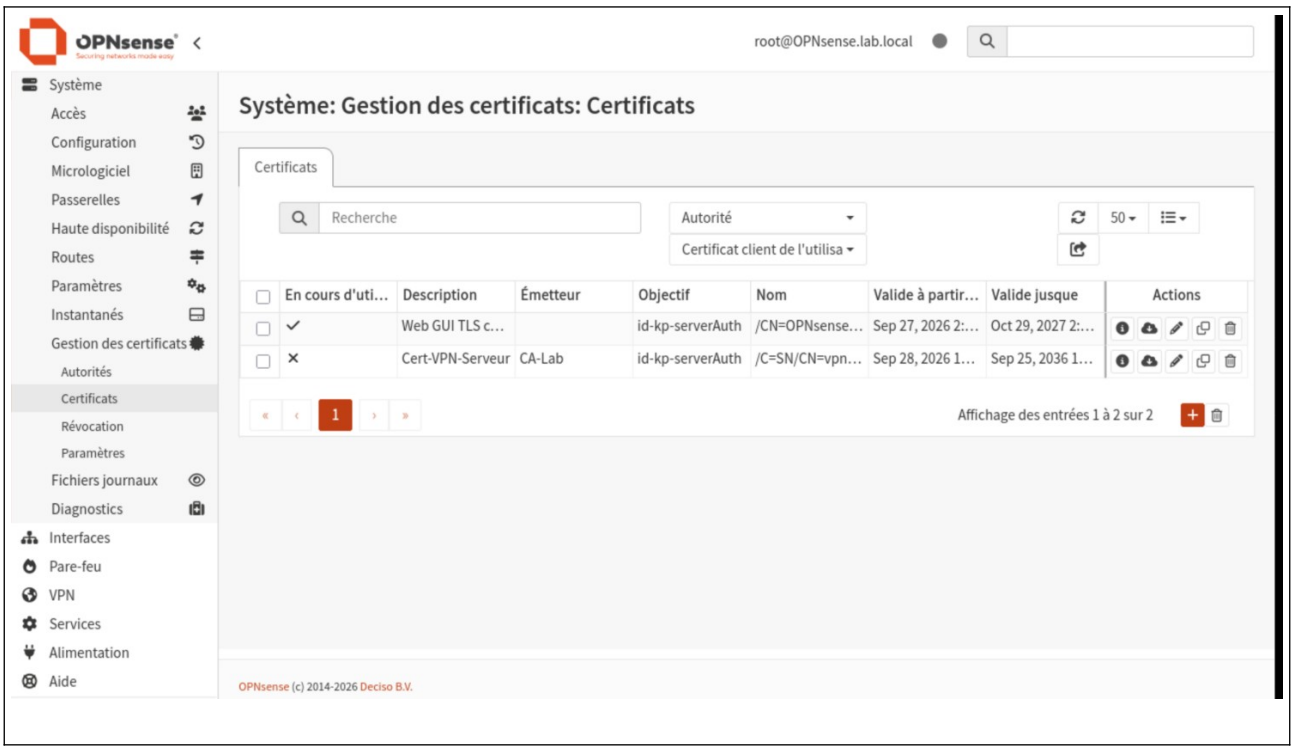
Le serveur doit prouver son identité au client. Cela demande un certificat.

1- Menu **Système → Gestion des certificats → Autorités**, bouton **+** :
   - Méthode : créer une autorité de certification interne
   - Description : CA-Lab
   - Nom commun : CA-Lab

2- Remplis les champs :
   - Méthode : Créer un certificat interne
   - Description : Cert-VPN-Serveur
   - Émetteur : CA-Lab
   - Type : Certificat serveur
   - Nom commun : vpn.lab.local
   - Noms alternatifs : ajoute deux entrées, un DNS vpn.lab.local et une adresse IP égale à l'IP WAN d'OPNsense

Laisse le reste par défaut (RSA-2048, SHA256) et clique sur Sauvegarder.

NB : Les noms alternatifs (SAN) du certificat serveur contiennent le nom DNS vpn.lab.local et l'adresse IP WAN d'OPNsense, afin que le client puisse valider l'identité du serveur quelle que soit la façon dont il le joint.



Le (x) dans « En cours d'utilisation » est normal : aucun service ne l'utilise encore. Il passera en (v) dès que nous allons l'associé à la connexion Ipsec.

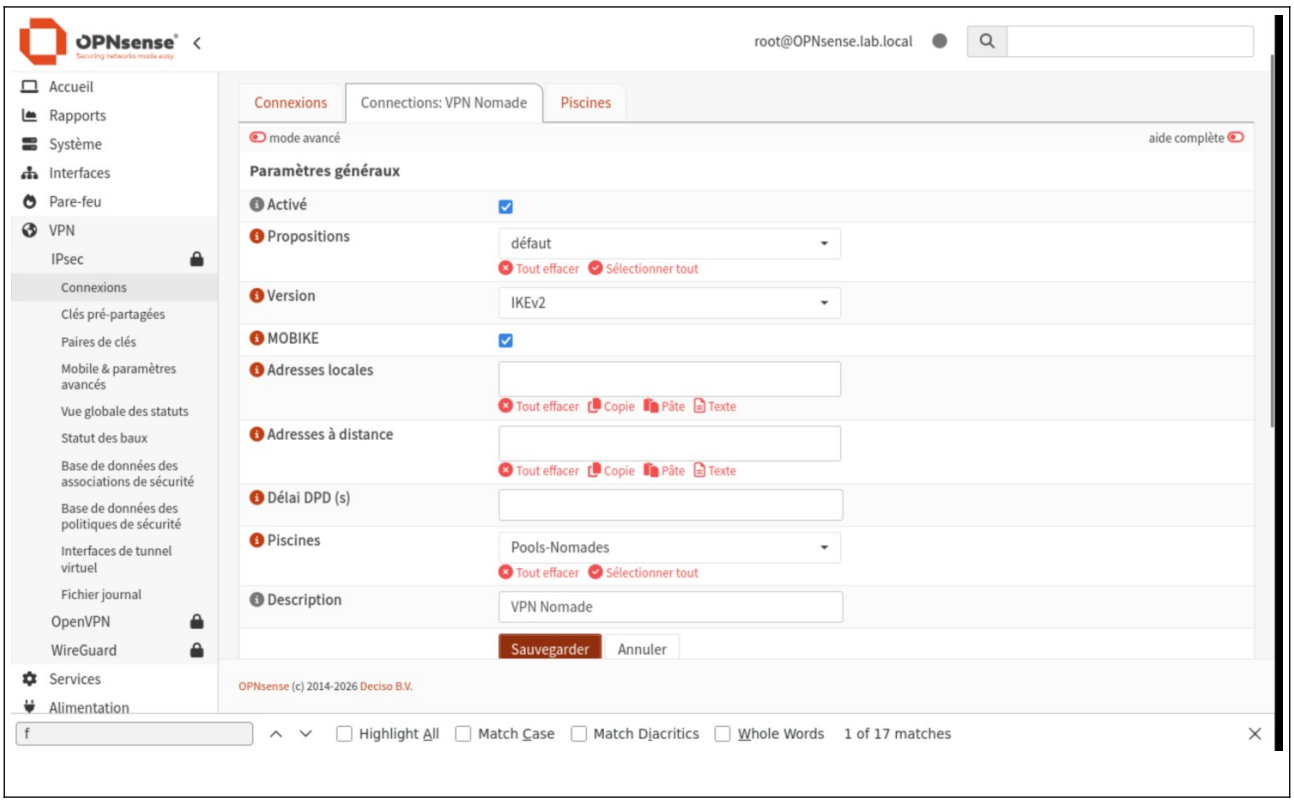
Un certificat serveur Cert-VPN-Serveur a été émis par l'autorité interne CA-Lab (RSA-2048, SHA256, validité 10 ans).

Étape 3 : création de la connexion

Menu **VPN → IPsec → Connexions**, onglet **Connexions**, bouton **+**.

Champ	Valeur
Activé	Coché
Propositions	Défaut
Version	**IKEv2**
MOBIKE	Coché (le tunnel survit au changement de réseau du client)
Adresses locales	Vide
Adresses à distance	Vide (l'IP des nomades n'est pas connue à l'avance)
Piscines	Pool-Nomades
Description	VPN nomade

Sauvegarder, puis rouvrir la connexion avec l'icône crayon. Trois tableaux apparaissent en dessous : Authentification locale, Authentification distante et Enfants. Ils ne sont accessibles qu'après cette première sauvegarde.



Étape 4 : authentification du serveur (locale)

Dans **Authentification locale**, bouton **+** :

Champ	Valeur
Round	0
Authentification	Public Key
Certificats	Certificat serveur créé à l'étape 2
ID local	vpn.lab.local

Sauvegarder.

Le serveur présente son certificat au client, qui vérifie qu'il parle bien au bon OPNsense.

Étape 5 : authentification de l'utilisateur (distante)

Dans **Authentification distante**, bouton **+** :

Champ	Valeur
Round	0
Authentification	EAP-MSCHAPv2
EAP ID	Vide

Sauvegarder.

Le client s'authentifie avec son nom d'utilisateur et son mot de passe local.

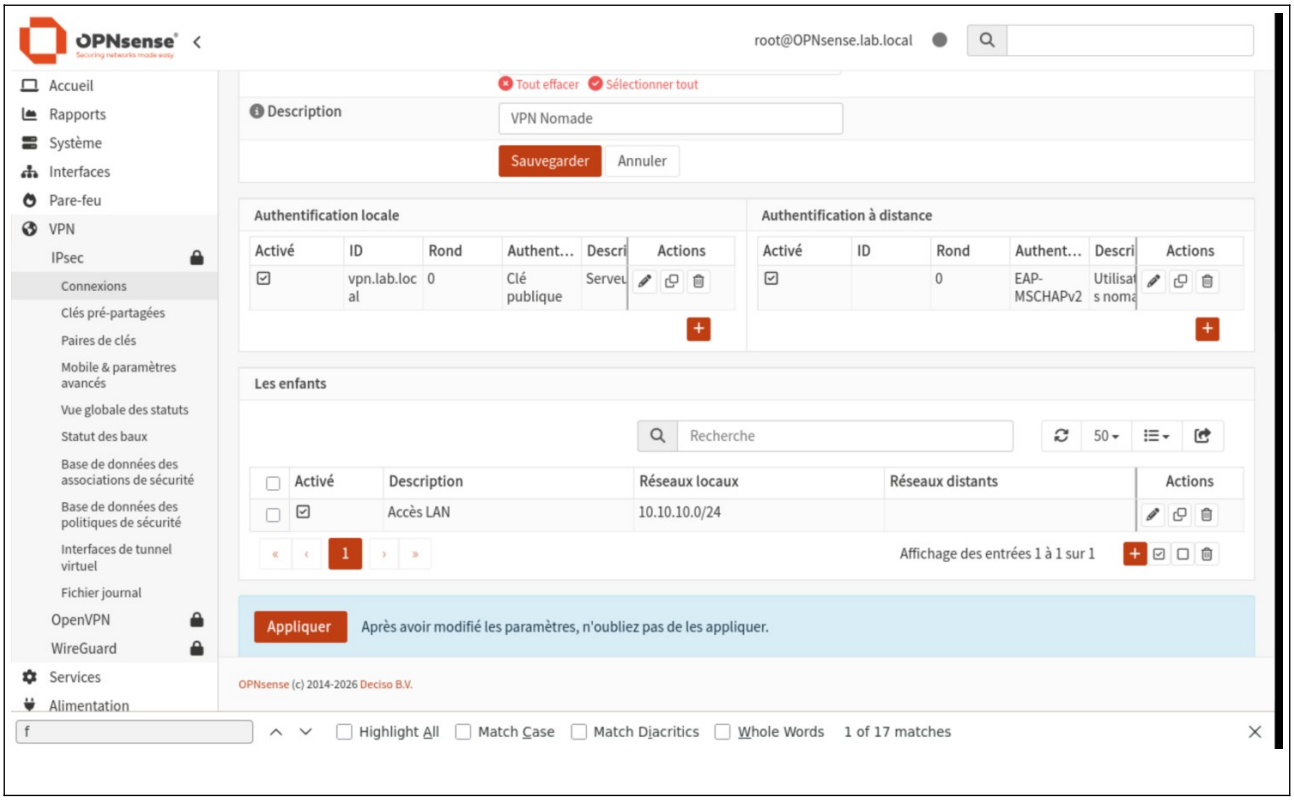
Étape 6 : réseau accessible (enfant)

Dans **Enfants**, bouton **+** :

Champ	Valeur
Mode	Tunnel
Local	10.10.10.0/24
Distant	Vide (adresse fournie par la piscine)
Propositions ESP	Défaut

Sauvegarder.

Seul le LAN est joignable par les nomades. La DMZ (10.10.20.0/24) est volontairement exclue : un utilisateur distant n'a pas à atteindre directement le serveur exposé, et c'est le principe du moindre privilège.



Étape 7 : création de l'utilisateur nomade

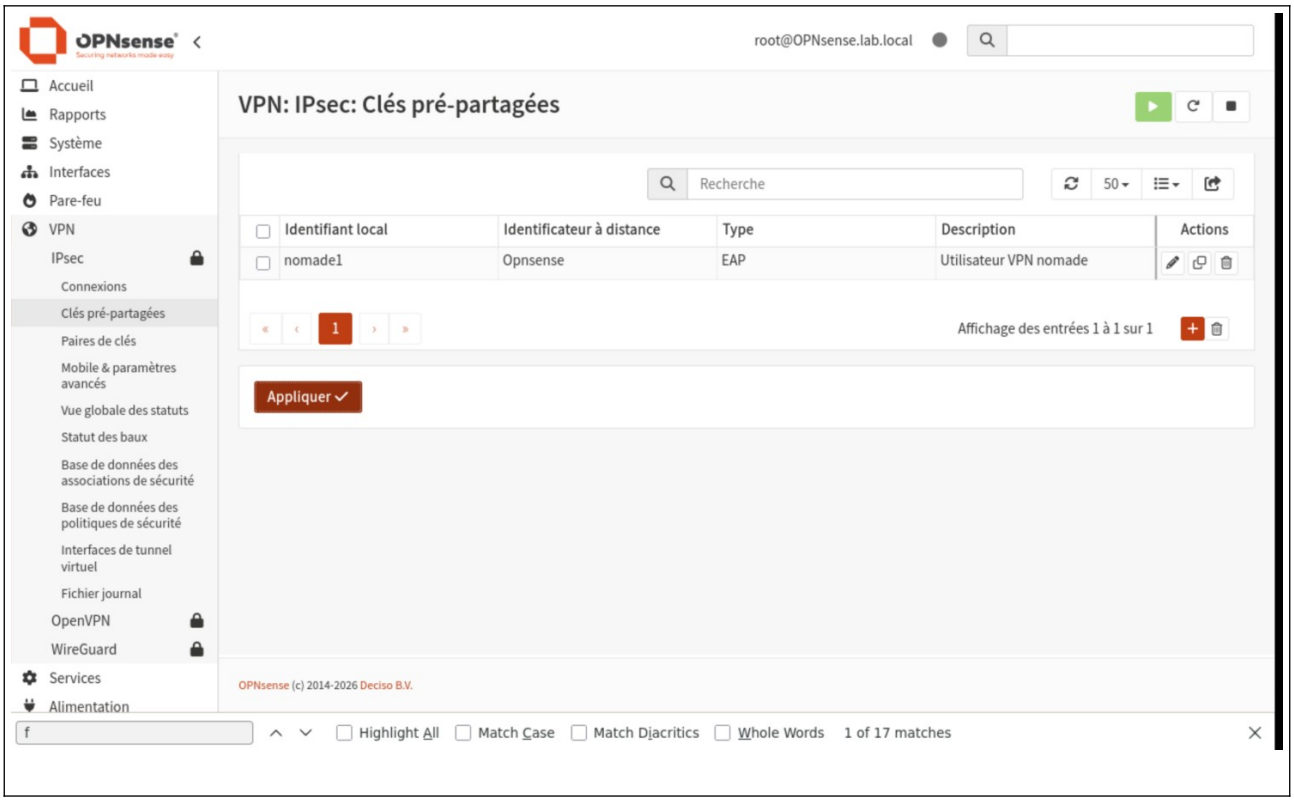
Menu **VPN → IPsec → Clés pré-partagées**, bouton **+**.

Champ	Valeur
Identifiant local	employe1
Clé pré-partagée	Mot de passe de nomade1
Type	EAP

Sauvegarder.

Étape 8 : application

Cliquer sur **Appliquer** sur les pages modifiées, puis vérifier que le service IPsec est démarré



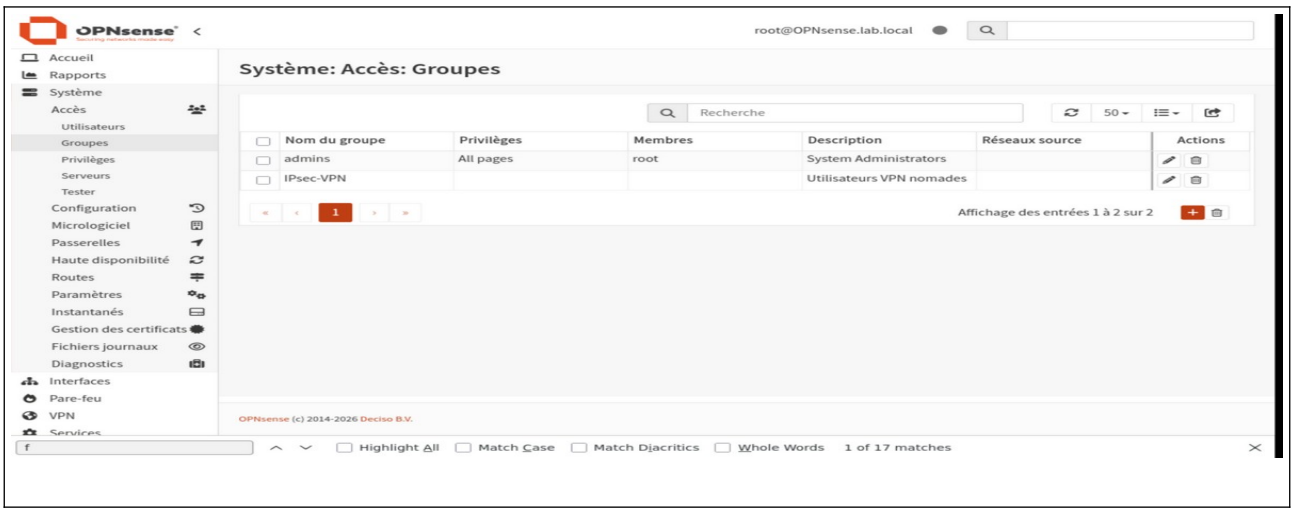
Le type **EAP** associe cette entrée à la méthode d'authentification EAP-MSCHAPv2. L'utilisateur saisira ce nom et ce mot de passe dans son client VPN pour ouvrir le tunnel.

Résultat attendu : un client nomade authentifié reçoit une adresse dans 10.10.30.0/24, utilise 10.10.10.1 comme DNS et ne peut joindre que le LAN 10.10.10.0/24.

9- 4 Création d'un utilisateur VPN

Étape 1 : groupe

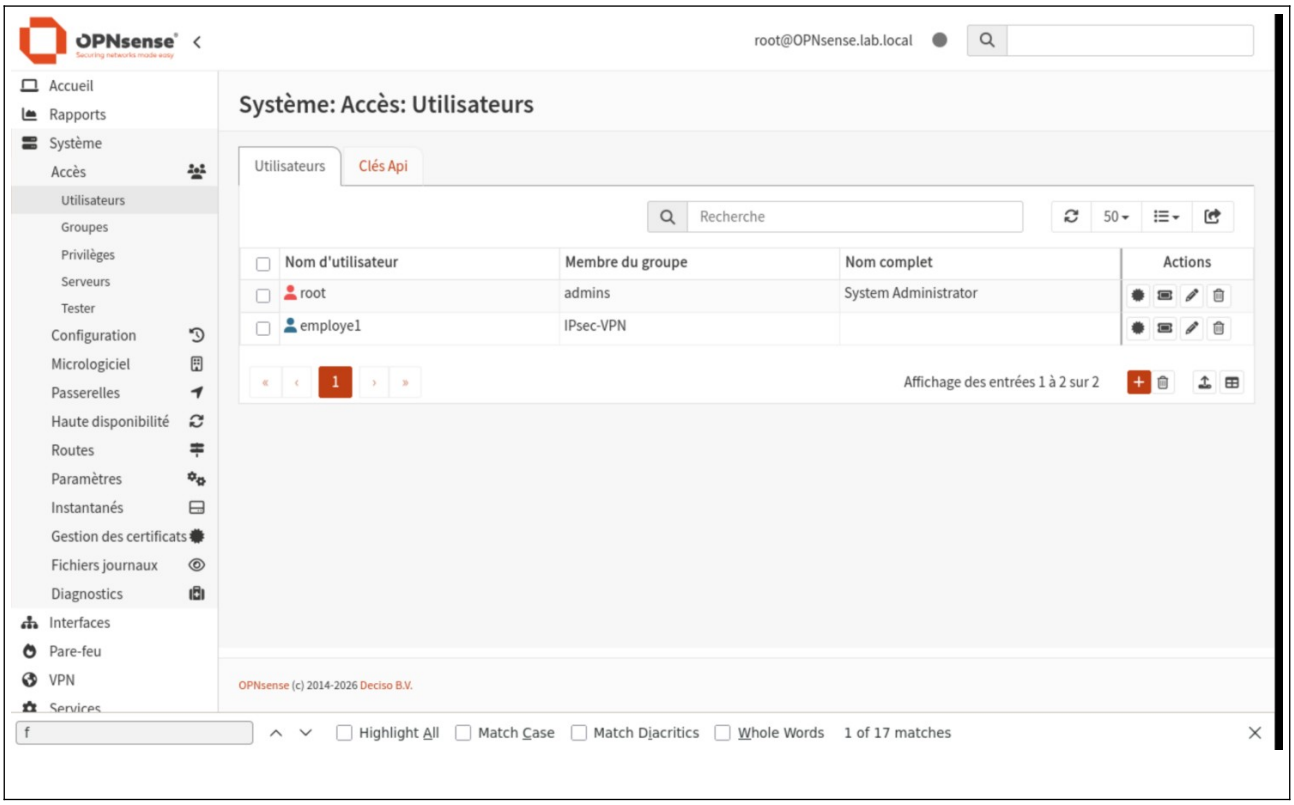
Menu Système → Accès → Groupes → + : création du groupe IPsec-VPN, auquel est attribué le privilège VPN: IPsec: Xauth Dialin. Ce groupe regroupe les comptes autorisés à ouvrir un tunnel VPN.



Étape 2 : utilisateur

Menu Système → Accès → Utilisateurs → + :

Champ	Valeur
Nom d'utilisateur	employe1
Mot de passe	Mot de passe employe1
Groupe	IPsec-VPN



Remarque : dans la configuration retenue (IKEv2 avec EAP-MSCHAPv2), les identifiants d'authentification sont également déclarés dans VPN → IPsec → Clés pré-partagées (type EAP). L'identifiant employe1 y a été repris pour assurer la cohérence entre les deux configurations.

9-5 Phase 1/ et Phase 2 côté serveur

En IKEv2, la « Phase 1 » correspond à la SA IKE, qui protège la négociation, et la « Phase 2 » à la SA enfant, qui protège le trafic des données.

Phase	Paramètre	Valeur	Emplacement
Phase 1	Version	IKEv2	Connexion → Version
Phase 1	Chiffrement	AES256-GCM, DH groupe 14 (2048 bits)	Connexion → Propositions
Phase 1	Authentification	EAP-MSCHAPv2	Authentification à distance
Phase 2	Protocole	ESP	Enfant
Phase 2	Chiffrement	AES256-GCM	Enfant → Propositions ESP
Phase 2	PFS	DH groupe 14	Enfant → Propositions ESP

Justification : AES256-GCM assure à la fois le chiffrement et l'intégrité des données. Le groupe DH 14 (2048 bits) fournit un échange de clés robuste. La PFS garantit que la compromission d'une clé de session ne permet pas de déchiffrer les sessions passées ou futures.

9- 6 Règle de pare-feu pour le VPN

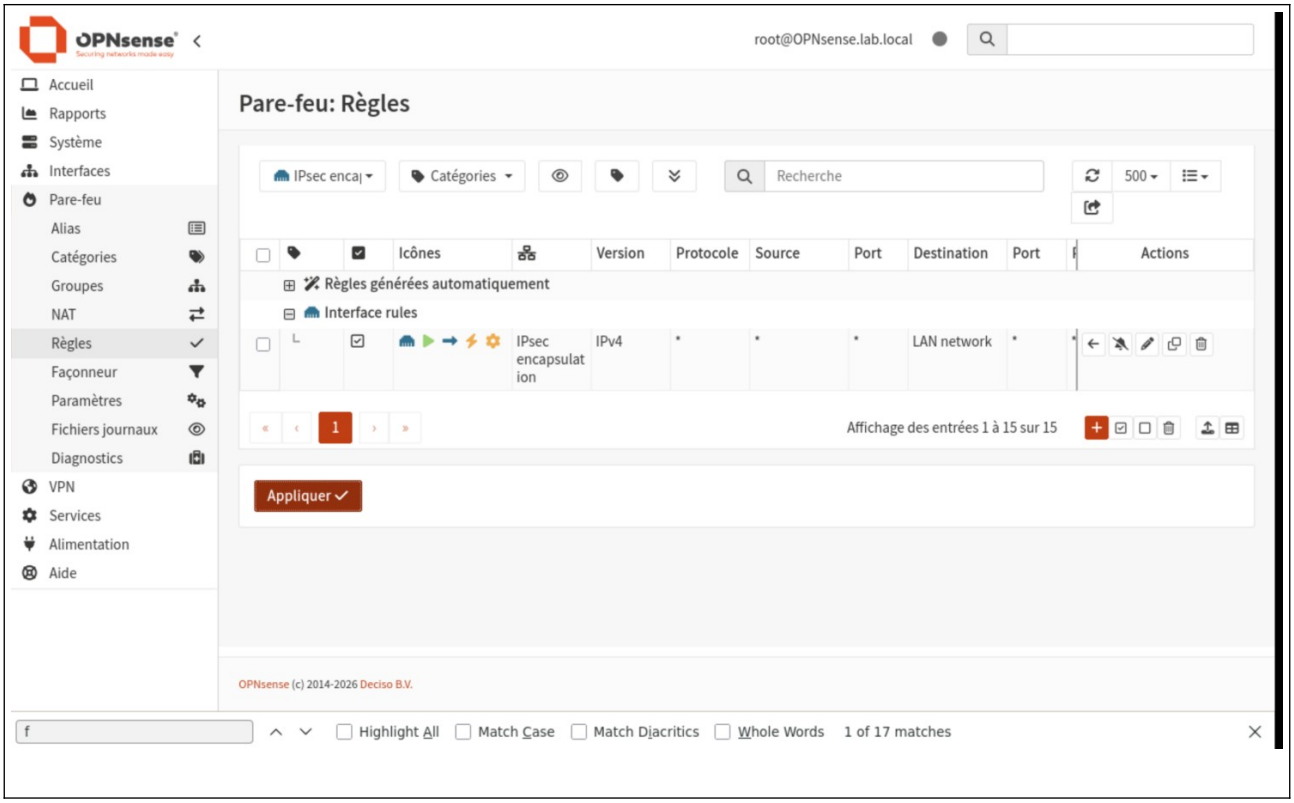
Objectif : autoriser les clients VPN connectés à communiquer avec le réseau LAN. Sans règle sur l'interface IPsec, le tunnel monte mais tout le trafic est bloqué par le refus implicite.

Accès au menu : Pare-feu → Règles → IPsec → « + »

Champ	Valeur
Action	Autoriser
Interface	IPsec
Protocole	any
Source	10.10.30.0/24 (pool des clients nomades)
Destination	LAN network (10.10.10.0/24)
Description	Clients VPN vers LAN

Isolation de la DMZ : la DMZ reste inaccessible aux clients nomades pour deux raisons.

- Le profil mobile ne déclare que 10.10.10.0/24 comme réseau local accessible,
- La destination de cette règle est limitée au LAN. Tout autre trafic est bloqué par la règle implicite de refus.



9-7 Configuration du client (VM Kali connectée sur le wan-net)

Objectif : simuler un employé en télétravail. La VM Kali est placée sur le réseau wan-net, donc « à l'extérieur » de l'entreprise, et ouvre un tunnel VPN IKEv2 vers OPNsense pour accéder au réseau LAN.

Étape 1 : installation de strongSwan

```
sudo apt update
sudo apt install -y strongswan strongswan-swanctl charon-systemd libcharon-extra-plugins
sudo systemctl enable --now strongswan
```

Étape 2 : transfert du certificat de l'autorité (CA-Lab)

Le client doit pouvoir vérifier le certificat présenté par le serveur. Kali étant placée côté WAN, elle ne peut pas atteindre l'interface web d'OPNsense (10.10.10.1, côté LAN) pour télécharger la CA directement.

La CA a donc été transférée en connectant temporairement Kali au réseau LAN :

1. Ajout d'une carte réseau supplémentaire sur lan-net dans virt-manager (en plus de la carte wan-net existante).
2. Vérification de l'obtention d'une adresse DHCP côté LAN (ip a, interface eth1, plage 10.10.10.0/24).
3. Ouverture de https://10.10.10.1 dans Firefox et export de la CA-Lab depuis **Système → Gestion des certificats → Autorités** (fichier CA-Lab_crt.pem).
4. Copie du certificat au bon emplacement :

```
sudo cp ~/Téléchargements/CA-Lab_crt.pem /etc/swanctl/x509ca/opnsense-ca.crt
```

5. Vérification du certificat :

```
openssl x509 -in /etc/swanctl/x509ca/opnsense-ca.crt -noout -subject -dates
```

Résultat : C=SN, CN=CA-Lab, valide du 28/09/2026 au 25/09/2036.

6. Désactivation de la carte lan-net avant le test du VPN, pour que Kali redevienne réellement « externe » :

```
sudo nmcli device disconnect eth1
```

7. Reconfirmation de l'IP WAN sur eth0 (192.168.100.110/24).

Étape 3 : configuration de la connexion

Fichier /etc/swanctl/conf.d/opnsense.conf :

```
connections {
```

```
  opnsense-vpn {
    version = 2
    remote_addrs = 192.168.100.127
    vips = 0.0.0.0

    local {
      auth = eap-mschapv2
      id = employe1
      eap_id = employe1
    }
    remote {
      auth = pubkey
      id = vpn.lab.local
    }
    children {
      net {
        remote_ts = 10.10.10.0/24
      }
    }
  }
}

secrets {
  eap-employe1 {
    id = employe1
    secret = "<mot_de_passe_employe1>"
  }
}
```

Points importants :

- le champ id du bloc local doit être renseigné explicitement (employe1), sinon strongSwan s'identifie par défaut avec son adresse IP, et le serveur ne retrouve pas le secret EAP correspondant ;
- aucune restriction proposals / esp_proposals n'a été imposée côté client : les valeurs par défaut négociées automatiquement (IKE : AES_GCM_16_256/PRF_HMAC_SHA2_384/MODP_2048 ; ESP :

AES_CBC_256/HMAC_SHA2_256_128) sont acceptées par le serveur, alors qu'une contrainte trop stricte côté client provoque une erreur NO_PROPOSAL_CHOSEN.

Étape 4 : correction de la clé pré-partagée côté OPNsense

Dans **VPN → IPsec → Clés pré-partagées**, l'identifiant local a été corrigé de nomade1 vers employe1 (type EAP), pour correspondre à l'identifiant réellement envoyé par le client.

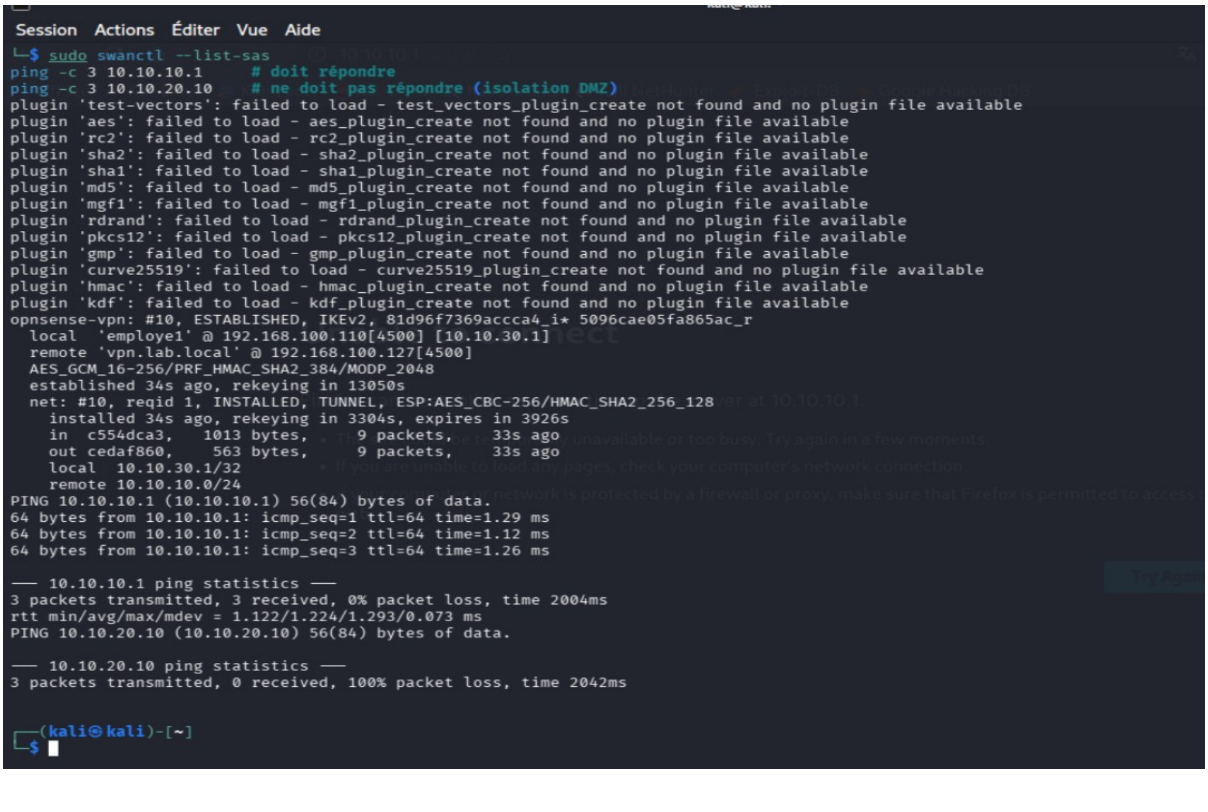
Étape 5 : établissement du tunnel

```
sudo swanctl --load-all
sudo swanctl --initiate --child net
```

Étape 6 : vérification

```
sudo swanctl --list-sas
ping -c 3 10.10.10.1
ping -c 3 10.10.20.10
```

Résultat : IKE_SA ESTABLISHED, CHILD_SA net INSTALLED, adresse virtuelle 10.10.30.1 attribuée depuis le pool 10.10.30.0/24, trafic effectivement échangé (paquets envoyés/reçus), LAN joignable, DMZ inaccessible.



10 – Envirennement Docker en DMZ

Prérequis résolus avant de commencer

A. Serveur SSH absent sur debian-dmz

openssh-server n'est pas installé par défaut sur Debian. Diagnostiqué via systemctl status ssh → Unit ssh.service could not be found. Installé manuellement.

B. Sources APT invalides

/etc/apt/sources.list ne contenait que l'entrée cdrom: héritée de l'installation, sans dépôt réseau. Remplacée par les dépôts officiels Debian (deb.debian.org, trixie).

C. Absence totale de sortie Internet depuis la DMZ

Constat : ping 8.8.8.8 et même ping 10.10.20.1 (la passerelle OPNsense elle-même) échouaient à 100 %, alors que l'adressage IP (des deux côtés) et le réseau virtuel libvirt (dmz-net) étaient corrects.
Cause : **aucune règle de pare-feu n'existait sur l'interface DMZ** dans OPNsense la politique de refus par défaut bloquait tout, y compris le ping vers la passerelle.
Correction : ajout d'une règle **Pare-feu → Règles → DMZ** : Autoriser / any / source DMZ net (10.10.20.0/24) / destination any.

Une fois ces trois points réglés :

```
apt update
apt install -y openssh-server
systemctl enable --now ssh
```

10- 1 Installation de Docker Engine et Docker Compose

Dépôt officiel Docker ajouté (fichier /etc/apt/sources.list.d/docker.list, distribution trixie), clé GPG importée, puis :

```
apt install -y docker-ce docker-ce-cli containerd.io docker-buildx-plugin docker-compose-plugin
usermod -aG docker debiandmz
```

Vérifié après reconnexion SSH (sans sudo) : docker --version → 29.8.1, docker compose version → v5.5.1.

Difficulté rencontrée : une première tentative avec le dépôt de.debian.org (mirroir alternatif) a cassé la résolution DNS et corrompu temporairement la liste des paquets, provoquant un conflit de dépendances sur openssh-server/openssh-client. Résolu en revenant à une seule source (deb.debian.org) et en relançant apt update.

Ajout temporaire d'une carte réseau NAT

La console VNC/SPICE de virt-manager ne permettait pas le copier-coller vers les VM (absence de partage de presse-papiers). Pour créer les fichiers de configuration sans risque d'erreur de frappe, une carte réseau supplémentaire a été ajoutée temporairement sur debian-dmz, connectée au réseau NAT (default, 192.168.122.0/24), permettant une connexion SSH directe depuis un terminal natif du poste hôte (avec presse-papiers fonctionnel). **Cette carte a été retirée immédiatement après la création des fichiers**, avant de reprendre les tests réseau, afin de ne pas fausser l'isolation de la DMZ.

10- 2 : création des fichiers du projet

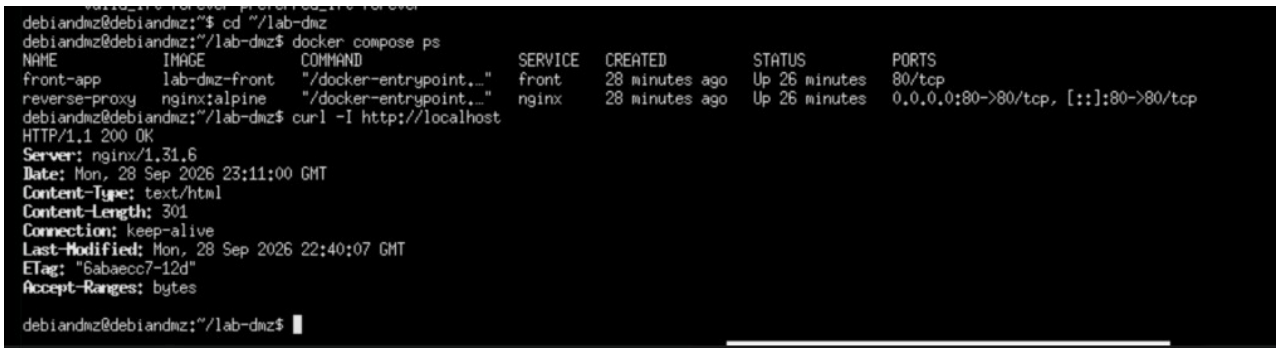
```
mkdir -p ~/lab-dmz/nginx ~/lab-dmz/front
```

- ~/lab-dmz/front/index.html page HTML statique
- ~/lab-dmz/front/Dockerfile image basée sur nginx:alpine
- ~/lab-dmz/nginx/default.conf configuration du reverse-proxy (proxy_pass http://front:80)
- ~/lab-dmz/docker-compose.yml deux services (nginx exposé sur le port 80 de l'hôte, front accessible uniquement en interne via le réseau Docker webnet)

10- 3 Démarrage et vérification

```
docker compose up -d --build
docker compose ps
curl -I http://localhost
```

Résultat :



Les deux conteneurs sont opérationnels, le reverse-proxy sert correctement la page du conteneur front en local.

10- 4 Test de bout en bout (Internet → OPNsense → DMZ → Nginx → Front)

Étape 1 : vérification de la règle de redirection NAT

Dans OPNsense : Pare-feu → NAT → Destination NAT.

Deux règles étaient déjà présentes (créées en amont, section 9.5 du guide) :

Interface	Protocole	Destination	Port	Redirection vers	Port
WAN	TCP	WAN adresse	http (80)	10.10.20.10	http (80)
WAN	TCP	WAN adresse	https (443)	10.10.20.10	https (443)

Aucune règle supplémentaire n'a donc été nécessaire pour ce test.

Étape 2 : test depuis l'extérieur (réseau wan-net)

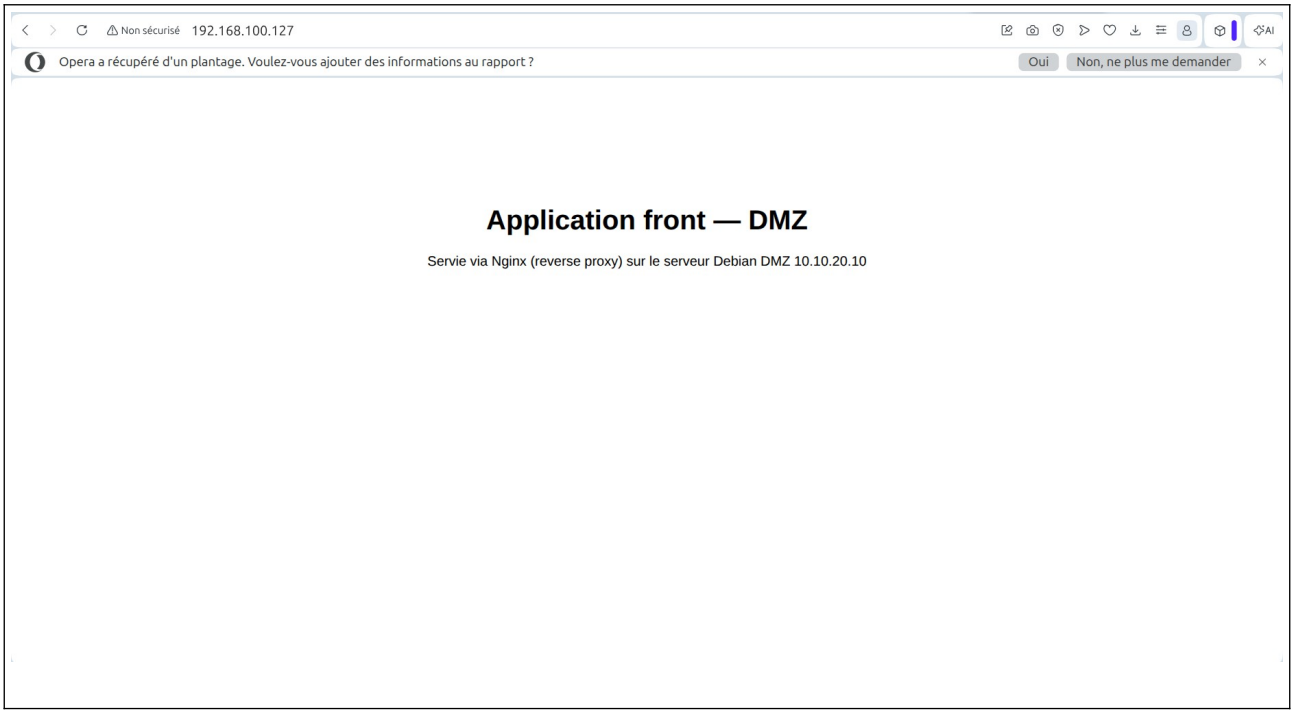
Depuis un navigateur sur le poste hôte (réseau wan-net, donc « à l'extérieur » du LAN/DMZ, au même titre qu'un visiteur Internet dans la topologie du lab), ouverture de l'adresse :

http://192.168.100.127

(l'IP WAN d'OPNsense)

Étape 3 : résultat obtenu

La page « Application front — DMZ » s'est affichée correctement, avec le texte : « Servie via Nginx (reverse proxy) sur le serveur Debian DMZ 10.10.20.10 ».



Conclusion

Le chemin complet de la requête a été validé de bout en bout :

Navigateur (wan-net) → OPNsense (Destination NAT, port 80) → 10.10.20.10:80

→ conteneur reverse-proxy (Nginx, seul port publié) → réseau Docker webnet → conteneur front-app

→ réponse HTML renvoyée jusqu'au navigateur

Cela confirme que : le port forward WAN → DMZ fonctionne, Nginx écoute et transmet correctement au conteneur applicatif via le réseau interne Docker, et le conteneur front (non exposé directement sur la machine hôte, uniquement accessible via webnet) reste bien isolé conformément au principe de moindre exposition.